INDEPENDENT SECURITY ASSESSMENT / 29 OCTOBER 2026

XITA Direct-BLS Interchain

Comprehensive security delta re-audit v3.2.0

OPERATING SCOPE	SOURCE DECISION
Self-funded core transfers	CONDITIONAL GO
Regular unattended sponsorship	NO-GO
Supervised core recovery	CONDITIONAL GO

Audit ID: **XITA-DBLS-2026-10-29-v3.2.0**

35 current entries: 28 residual risks and 7 resolved causes.
All 32 prior current findings and 43 historical occurrences reassessed.

62 Interchain commits / 48 changed paths / zero node delta.

Authorized frozen source

xgr-network/xgr-interchain / main
5cfc095d0f02271427832ee6bbb268322f38ae2d

xgr-network/xgr-node / XGR3.0
51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671

OpenAI GPT-6 Astra - AI-assisted independent assessment commissioned by the project owner. This is not a human audit-firm attestation.

Complete English report. Private reproductions and the exact pre-history Phase A master are separately retained. Source defects, deployment observations and missing assurance are distinguished.

Contents

1. Executive summary and overall decision 3

2. Exact source baselines, identity and scope 5

3. Complete change inventory and adjacent coverage 6

4. Methodology, independence and test environment 10

5. Independent Phase A results 11

6. Complete Phase B finding reclassification 12

7. Sponsorship security and financial obligations 37

8. Protocol, consensus, principal and recovery assessment 42

9. Tests, negative controls and evidence 44

10. Production observations and deployment limitations 46

11. New findings and regression deduplication 47

12. Residual risks, assumptions and acceptance 52

13. Separate release decisions and conditions 53

14. Remediation matrix and implementation order 55

15. Final statistics, artifact integrity and conclusion 59

Reading guide: section 6 re-evaluates every prior finding; section 7 assesses all ten sponsorship invariants; section 11 details the three new findings. Section 13 separates the three operating decisions. The full inventory, exact tests and archive identities accompany this report.

1. Executive summary and overall decision

The full delta contains 62 Interchain commits, including three merges, and 48 changed/touched files. All 27 product, migration and test paths and all 21 historical audit/index artifacts have documented review coverage. The node branch has no changes from its previous audited commit. All current contracts and recorded deployment manifests are unchanged. Adjacent authorization, accounting, finality, recovery, API, database, wallet and release boundaries were traced rather than treating unchanged line ranges as automatically safe.

The audit independently discovered four Phase A candidate classes. Historical reconciliation maps the role/readiness class to reopened F-06 and assigns three new IDs: F-33 (Medium, late payout effect after timeout), F-34 (Low, provisional spendable-state divergence) and F-35 (Low, optional gas-observer progress). No new Critical or High defect was demonstrated. F-07, F-16 and F-30 can now be closed for their original technical causes; F-01, F-02, F-26 and F-27 retain verified closure after regression checks. Legacy synchronization finding 2026-10-24/M-03 advances to verified source closure. These closures do not imply that the complete sponsoring service is approved.

Operating scope	Decision	Basis and boundary
Core Direct-BLS / self-funded transfers	CONDITIONAL GO	Verified native fixes, unchanged authorization contracts and positive deployment observations support a restricted scope. External witness trust, native-claim presentation, managed quote availability and recovery conditions remain explicit.
Optional gas sponsorship / two-hop obligations	NO-GO for regular unattended operation	F-33 demonstrates a new post-timeout payout effect. F-06 breaks supported restricted-role admission/monitoring. F-08 and F-19 prevent an unconditional autonomous servicing claim. This is a source decision, not an assertion of observed production exploitation.
Recovery / operational availability	CONDITIONAL GO	Supervised validated core proof/delivery recovery and read-only sponsor journal/evidence inspection, with active backlog monitoring and documented finite recovery limits. The unsafe automated sponsor replay path is excluded until its effect boundary is corrected or a separately assessed workflow demonstrably avoids it.

The sponsoring NO-GO is driven by concrete local counterexamples and unresolved financial-effect/lifecycle control. It is not inferred from missing host attestation or from the word Medium. The public health endpoint currently advertises available sponsorship; no production failure, payout, principal loss or exploitation was induced or asserted. Source safety and installation evidence are assessed independently throughout this report. When an unobserved installation fact would decide a release question, the appropriate next step is a targeted request for existing sanitized evidence.

Current residual severity	Unique findings
Critical	0
High	0
Medium	14
Low	12
Informational	2
Resolved original causes	7

Current residual severity	Unique findings
Total register entries	35

The 35-entry register contains 28 unresolved entries and seven resolved original causes. Its dispositions are 24 OPEN, three PARTIALLY_MITIGATED, one ACCEPTED_RISK and seven VERIFIED / RESOLVED. The separately preserved 43 historical occurrences are not additional unique current findings. Historical severity is retained, including prior High conditions whose current residual severity is lower.

Management view of Medium findings

Category	IDs	Meaning
SCHLIESSBAR	F-02, F-07, F-16, F-26, F-30	Original Medium causes have sufficient source/test evidence for code-audit closure. Includes prior verified causes rechecked for regression.
OFFEN	F-03, F-04, F-05, F-06, F-08, F-09, F-11, F-17, F-19, F-20, F-21, F-29, F-32, F-33	All 14 current Medium risks; OPEN, PARTIALLY_MITIGATED and ACCEPTED_RISK remain open in this management view.
OFFEN	F-15 (historically Medium; now Informational)	The previous current-outage premise is superseded by fresh health evidence. Installation assurance is incomplete and is kept visible without counting a current Medium or inventing an outage.

Legacy-only Medium closures remain in the 43-occurrence matrix. In particular, M-03 has a fresh complete signing-entrypoint source proof; the absent dedicated behavioral regression is disclosed rather than turned into a surviving defect. F-15 is now Informational because the current observed endpoint is healthy and the remaining issue is installation assurance. F-11 remains OFFEN in the two-category management view despite its previously documented ACCEPTED_RISK disposition.

2. Exact source baselines, identity and scope

The source freeze was established at **2026-10-29T08:49:12.369544Z**, before independent review. Git existence, ancestry and the prior audit's source-freeze metadata agree with the authorized baselines. Only the two authorized development repositories were accessed. Existing historical evidence was read as archived evidence; no third development repository was substituted.

Repository / branch	Previous baseline	Frozen target
xgr-network/xgr-interchain / main	26d1356ce7c92eed67bfdbb91a5a0b19efc25ae3	5cfc095d0f02271427832ee6bbb268322f38ae2d
xgr-network/xgr-node / XGR3.0	51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671	51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671

Interchain baseline tree is `de63f3712463012a9fdb1efdeff81d30524a0ef6`; target tree is `4b19f296d2791eec0a98b1f0e4e60ca0225963f9`. Node baseline and target tree are `3c5d1a0a1e7264b8b7c5787ca390e976fed09b04`. The complete Interchain endpoint diff SHA-256 is `852139e49f3dbd60c58117a350def496437dcc87a1e0c398e26cca1c9db06e70`. Node's empty delta has the SHA-256 of an empty byte string, recorded explicitly rather than represented by an empty placeholder artifact.

The full reachable commit list includes merge commits and all individual-commit touched paths. The union of those paths is the same 48 paths as the endpoint diff; there are no additional reverted-only source paths. Full endpoint and per-commit patches, tree listings, commit-to-file mapping and review evidence are archived. The post-freeze audit commits are publication artifacts and are not audited product revisions. Later upstream product changes are outside this assessment unless explicitly re-evaluated.

The prior audit directory names and reports remain historically intact: 24 October v1.0.0; 25 October reassessment v2.0.0; 27 October full v3.0.0; and the corrected 27 October v3.1.0 supplement. The latter is the authoritative recent decision baseline. It is explicitly a correction supplement, not the unarchived 90-page draft described in earlier history. Original v1/v2 complete confidential report identities are not silently claimed verified from public summaries. The exact current 43-occurrence register and actual retained v3.0/v3.1 bytes provide the documented historical boundary.

The source scope includes Direct-BLS **per message**. Message serialization, aggregate proof, route and deployment domains, current validator membership/quorum, exact source event and fee evidence, native versus external-chain finality, replay state, contract ownership, native/wrapped principal accounting, deferred claims and one-hop/two-hop execution are the inspected security boundaries. No obsolete Merkle-based model is used.

3. Complete change inventory and adjacent coverage

The machine-readable `change-inventory.csv` contains all 48 paths, every associated commit, component, security relevance, frozen SHA-256, completed review status and evidence references. Every product path below was read in full together with relevant callers, transaction boundaries and failure paths. Tests were inspected for what they actually assert; a new test filename or green exit was not treated as complete coverage.

Changed path	Security review and execution boundary
apps/web/app.js	Spendable added to status allowlist. Traced sourceHash/account/message key reset, refreshed source-evidence gate, render path and current-balance preflight before resumeDelivery signing.
apps/web/transfer-actions.js	Entire startTransfer and resumeDelivery reviewed: unsigned preview only adjusts preflight gas envelope; canonical route, EIP-712 quote, amount, recipient, chain and real wallet gas checks remain before eth_sendTransaction. Preview outage fallback 1.2m gas retained.
apps/web/transfer-gas-profile.js	Complete code-hash keyed profile and integer rounding reviewed with quote/protocol tracks. One-sample to twenty-sample margin, bounds, missing sample fallback, state/proof-size dependencies identified.
apps/web/transfer-gas-profile.test.mjs	Full two-test suite read and executed; boundary samples and code-hash change covered; dynamic validator workload not demonstrated by these tests.
apps/web/transfer-sponsor-evidence.js	Complete module reviewed. Positive committed grants require ok and confirmed/spendable status; zero-grant path independently exact-bound. Backend spendable liveness weakness cross-referenced sponsor track.
apps/web/transfer-sponsor-evidence.test.mjs	All 4 tests executed; positive commitment status gates and exact zero-grant source binding reviewed.
apps/web/transfer-status-flow.js	Complete flow renderer and mapped stage data inspected; spendable text correctly distinguishes inclusion from finality but depends on backend fresh evidence. Existing flow regression suite31/31 passes.
services/indexer/gas-observer-runner.mjs	Read startup DB config, catalog snapshot per tick, no key access, signal handling, 12-second poll and catch/finally paths. No production install inferred.
services/indexer/gas-observer.mjs	Entire collector traced incl profile lookups, shared-Mailbox logs, finality, canonical block, cursor and error handling. Permanent unprofileable record stalls cursor reproduced.
services/indexer/gas-observer.test.mjs	Reran existing success/failure/finality cases; added chain mismatch, expected block mismatch, and both cursor stall cases.
services/indexer/sql/013_sponsor_prepared_tx.sql	Prepared bytes, unique hash, restricted writes, grant lifetime
services/indexer/sql/014_sponsor_overtaken_obligations.sql	Append-only paid obligations and role boundaries
services/indexer/sql/015_sponsor_spendable_receipt.sql	Separation of provisional inclusion and safe confirmation

Changed path	Security review and execution boundary
services/indexer/sql/016_gas_profiles.sql	Full constraints, per-profile lock, deduplication, pruning, percentile and role grants read; applied successfully to isolated PG. Root/sponsor track tests row retention.
services/indexer/xita-gas-observer.service.example	Read all settings; dedicated observer script, no signer env, read-only home/filesystem, restart and user conditions. Existing transfer-worker role is shared, not independently least-privileged.
services/managed-relay/gas-sponsor.mjs	Sponsorship authorisation; durable signed-byte journal; bounded RPC/replay; canonical inclusion/finality; expiry witnesses; sweep lifecycle
services/managed-relay/gas-sponsor.test.mjs	Existing verification of nonce identity, gas principal separation, receipt finality, restart and witness disagreements
services/managed-relay/quote-service.mjs	Full control flow; new three profile estimates feed fee and sponsorship allocation before EIP-712 binding; native principal subtraction retained.
services/managed-relay/quote-service.test.mjs	Read and reran all cases, including learned gas and complete two-hop stage commitment.
services/managed-relay/server.mjs	Full request, quote creation, runtime binding, new profile DB reads, public spendable status and response-after-persistence paths reviewed; readiness privilege omission reproduced.
services/managed-relay/sponsor-obligation-audit.mjs	Read-only paid-liability aggregation and immutable alert aging
services/managed-relay/sponsor-obligation-audit.pg.test.mjs	Real schema atomic journal, monitor age and obligation edge cases
services/managed-relay/sponsor-obligation-audit.test.mjs	Aggregate query and no-write boundaries
services/managed-relay/sponsor-quote-atomic.test.mjs	Read and reran; additional real PostgreSQL concurrency, failure and rollback proofs added outside product.
services/managed-relay/sponsor-status.test.mjs	Public provisional grant and aggregate stage projections
services/managed-relay/tax-evidence.mjs	Full transaction and lock order reviewed. New SELECT intents omits supported role grant; genuine concurrent limits and rollback tested.
services/managed-relay/tax-evidence.test.mjs	All existing tests reran; text-match admission test supplemented with actual role and concurrent DB cases.

Historical artifacts in the delta

The 21 audit/index changes were inventoried during Phase A but their findings and conclusions were read only after the independent seal. Phase B compared actual artifacts and checksums, reconstructed technical causes, and retained the original historical cells while adding the current overlay.

Historical artifact path	Review result
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/README.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.

Historical artifact path	Review result
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/archive-manifest.json	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/baseline-findings.csv	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/confidential-evidence-reference.json	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/delta-assessment.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/evidence-public.zip	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/evidence/MANIFEST.json	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/evidence/README.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/findings.csv	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/historical-findings.csv	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/launch-decision.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/pdf-validation.json	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/phase-a-findings.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/phase-a-freeze.json	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/prior-findings-matrix.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/remediation.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/report.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/report.pdf	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/verification.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/2026-10-27-xita-direct-bls-delta-v3.1.0/verify_artifacts.py	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.
audits/README.md	Exact identity and complete historical overlay reviewed after Phase A; unchanged by this publication.

Unchanged components and dependencies

There are zero node delta commits and zero changed node paths. The protocol track additionally compared 126 adjacent Interchain files and 120 node files, including all 26 Solidity sources. It freshly traced 22 named protocol/control boundaries and, during historical reconciliation, compared 54 specific source files: 43 node and 11 Interchain. These are identity checks plus the stated focused source traces, not a claim that every unchanged repository line was newly audited.

Contracts, deployment manifests, dependency declarations, compiler configuration and CI workflows are unchanged over the requested delta. Recorded contract approvals cover 57 deployments and 43 distinct approval commits; executable source identities match. The v3.4.0 node tag `cbe6f8a4ae1718429a9924dcf87f0d28591d74e1` differs from the frozen node only in three Markdown files. This establishes source equivalence for the release boundary without inventing a fresh compilation or attestation for every installed binary. See `evidence/protocol/source-identity.json`, `approval-source-identity.json` and `phase-b-source-identity.json`.

The requested merged sponsorship changes, including PRs #357, #358, #360 and #361, are evaluated through their actual reachable commits and complete current code. Commit titles and PR success do not determine closure. The full commit-to-path inventory also covers all other merged changes, including unsigned previews, spendable status, gas-profile migrations, observer service configuration and final monitor/admission changes at the frozen HEAD.

4. Methodology, independence and test environment

The coordinating auditor froze both repositories before assessment and assigned independent sponsorship, quote/gas-observer and protocol/contract/node tracks while tracing integration, frontend, indexer and administration locally. Before the Phase A seal, only the previous source-freeze metadata was read for baseline provenance. The commissioning brief itself named selected historical findings and priorities; that unavoidable exposure is disclosed. Detailed historical reports, registers, conclusions and reproduction evidence were deferred until Phase B.

The Phase A master was completed at **2026-10-29T08:55:39.812188Z** and committed before detailed historical reconciliation. Its SHA-256 is `8a6651e9ed0167e7605dab9d129a0fa8019833a37bb5bd348373dadc5bf49a52`. The freeze covers 126 component/source/test artifacts. The protected archive preserves the exact sealed master, and earlier immutable audit checkpoints remain part of the audit trail. The current public `phase-a-findings.md` is an explicitly labelled publication-safe derivative which removes two detailed private-fixture sequences and clarifies evidence access. `phase-a-publication.json` records both identities. Redaction does not change discovery timing, findings or the original sealed bytes.

The environment used Node v24.22.1, npm 11.9.0, Python 3.12.14, Git 2.51.1, ethers 6.13.4 and pg 8.16.3 matching repository pins. PostgreSQL 16.15 ran in a dedicated temporary cluster on localhost port 55432, with separate disposable databases for each track. Complete repository migrations were applied for privilege, locking, rollback and fairness tests. When an extra SELECT was temporarily granted to isolate a second control, the canonical-role failure was demonstrated first and the fixture-only change was explicitly recorded. Product modules were imported unchanged and checked against frozen Git blobs.

New verification uses unit/regression executions, actual-function mocks, deterministic delayed RPC responses, controlled canonical/finality disagreement, temporary filesystem locks and real PostgreSQL sessions. These methods examine failures without creating real transfers. Negative tests deliberately asserting an unsafe outcome are labelled defect reproductions. Existing real logs are recovered and checked before use; inherited execution and fresh source equality are not described as new execution. No fresh Go or Foundry run is claimed.

No productive token transfer, sponsor payout, user wallet signature, contract deployment, production database modification, validator/service change or obligation release/deletion occurred. Live calls were read-only. Optional public health was observed without requesting a signed quote or creating a reservation. No traffic saturation or production fault injection was attempted.

Confidence describes the strength of the stated source/control-flow conclusion. High confidence in a local counterexample does not imply that it occurred in production. A source issue, a test-coverage issue, an installation assurance gap and a directly observed production condition are recorded separately. Existing deployment receipts and runtime identities support only the addresses and endpoints observed at their recorded times.

5. Independent Phase A results

Phase A produced four candidate classes before historical mapping. A-01 encompasses missing new restricted-role reads; it maps to the existing F-06 cause and is counted once. A-02 maps to new F-33. A-03 includes two faulty provisional-spendable transitions and maps to one new F-34. A-04 maps to new F-35. The root's contradictory RPC test observation maps to F-14 and is not a new principal-security defect.

Independent candidate	Current mapping	Independent result
A-01 / A-Q1 plus monitor instance	F-06 reopened, Medium	Real canonical-role PostgreSQL admission and monitor reads fail despite incomplete readiness; rollback preserves quote consistency.
A-02 / A-SP-01	F-33 new, Medium	Actual-function delayed recovery can start the original prepared broadcast after timeout and destination completion.
A-03 / A-SP-02 and A-SP-03	F-34 new, Low	Crash inclusion and receipt disappearance expose incomplete provisional state transitions.
A-04 / A-Q2	F-35 new, Low	Permanently uncatalogued optional gas observations can hold a cursor indefinitely.
A-R-01 verification observation	F-14 existing, Low	An unchanged RPC test contains contradictory expectations; its failure is disclosed and not used as protocol-failure evidence.

The independent traces found no new demonstrated source-principal bypass, arbitrary token issuance, unauthorized BLS message, uncontrolled nonce reuse, additional sponsorship user signature or sponsorship of user-funded native principal. This is a bounded negative result from the specified inspection and tests, not an assertion that all possible attacks were disproven.

Dynamic gas profiles are keyed by chain, stage, representation/operation, executor bytecode and router bytecode. The integer margin decreases from 2.0 at one sample to 1.3 at twenty samples. Current verifier work also depends on validator membership and selected-signature count, which can change without a runtime-code change. The audit did not quantify a workload exceeding the margin or demonstrate a grant deficit from that dimension. It therefore records an unmeasured design/coverage consideration, not an invented additional Medium. Conservative stale-profile fallback and workload-aware measurements are appropriate focused follow-up tests. F-35 separately has a reproduced availability cause.

6. Complete Phase B finding reclassification

Every F-01 through F-32 was reconstructed against the authoritative corrected v3.1 register, complete v3.0 assessment, historical occurrences and associated evidence. The machine-readable current register uses original severity, current residual severity, technical disposition, management category, source identity, cause, delta, evidence class, limits and minimal remediation. Earlier literal NEW markers on F-30/F-31/F-32 are preserved as provenance while their historical severity for this delta is Medium/Low/Medium; they are not new v3.2 findings.

ID	Current severity	Disposition	Title
F-01	RESOLVED	VERIFIED / RESOLVED	Native system-transaction accounting and proposal validation
F-02	RESOLVED	VERIFIED / RESOLVED	Transaction-original storage and refund accounting
F-03	Medium	OPEN	Expensive gossip work lacks complete admission bounds
F-04	Medium	OPEN	Shared observer retry fairness and failure isolation
F-05	Medium	OPEN	External source witnesses retain correlated-provider trust
F-06	Medium	OPEN	Restricted-role reads and readiness omit new quote/monitor dependencies
F-07	RESOLVED	VERIFIED / RESOLVED	Sponsor reservation can strand the sender nonce after interruption
F-08	Medium	PARTIALLY_MITIGATED	One grant RPC failure can block all-chain sponsorship
F-09	Medium	OPEN	Mailbox completion can conceal a pending native-principal claim
F-10	Low	OPEN	Authorized ownership transfer can collapse service/admin separation
F-11	Medium	ACCEPTED_RISK	Membership authorizations omit the exact registry deployment
F-12	Low	OPEN	Minimum validator committee size remains an operating rule
F-13	Low	OPEN	Wallet proof calldata is not fully bound to selected intent
F-14	Low	OPEN	Regression fixtures and CI discovery drift from the current product
F-15	Informational	OPEN	Production sponsorship and installation readiness remain unproven
F-16	RESOLVED	VERIFIED / RESOLVED	Expiry-release evidence trusts one RPC without a canonical reread
F-17	Medium	PARTIALLY_MITIGATED	Unpaid payer aliases still occupy finite sponsor admission capacity
F-18	Low	OPEN	Conservative daily-limit accounting can count a liability twice
F-19	Medium	PARTIALLY_MITIGATED	Paid grant lifecycle can remain unresolved after early delivery or shutdown
F-20	Medium	OPEN	Pending recovery work can be removed before durable replacement
F-21	Medium	OPEN	Successful incomplete discovery responses can advance durable cursors

ID	Current severity	Disposition	Title
F-22	Low	OPEN	Admin deployment evidence uses confirmation depth as finality
F-23	Low	OPEN	Orphaned deployment locks require careful manual recovery
F-24	Low	OPEN	Verified paid-fee backfill still omits required event identity
F-25	Low	OPEN	Dense event windows lack adaptive progress
F-26	RESOLVED	VERIFIED / RESOLVED	Unknown route rows can starve background delivery refresh
F-27	RESOLVED	VERIFIED / RESOLVED	Published CLI version fields are empty despite valid embedded VCS data
F-28	Informational	OPEN	Compiler advisory applicability remains an assurance gap
F-29	Medium	OPEN	Membership and governance submission RPC remains unbounded
F-30	RESOLVED	VERIFIED / RESOLVED	Reconciliation refresh suppresses delayed-grant monitoring
F-31	Low	OPEN	A failed destination receipt can retain transaction-submitted wording
F-32	Medium	OPEN	Expired unverified route hints leave permanent per-message request storage
F-33	Medium	OPEN	Timed-out sponsor recovery can initiate a late prepared payout
F-34	Low	OPEN	Provisional spendable state diverges from recovered or current receipt evidence
F-35	Low	OPEN	An out-of-scope record can indefinitely stall optional gas observation

The following detailed sections address all 32 prior current IDs. New F-33 through F-35 are detailed in section 11. Source links identify the exact frozen revisions. Relative raw-evidence references within a track resolve under that track in the protected archive; matching public summaries and hashes are in `evidence/`. No protected fixture is implied to be a public repository file.

F-01 - Native system-transaction accounting and proposal validation

RESOLVED / P1 / VERIFIED.

Original cause. Native StateTx execution could receive ordinary refund/fee credits without a matching upfront debit. The proposer-validation boundary did not restrict admissible system transactions tightly enough or require deterministic header base-fee equality. The original prerequisite was proposer-controlled block content, not an ordinary bridge UI action.

Current assessment. The joint securityAccounting fork rejects executable StateTx in Apply, restricts block processing to the exact non-executing epoch marker, checks the marker in both proposal and block verification, and checks header base fees against the checked parent-state calculation. The retained independent rejection/accounting tests target this corrected node commit. Local four-validator execution crossed the fork and agreed on selected block hashes. The fixed source is release-equivalent to v3.4.0; fresh rpc1/rpc2 observations report v3.4.0 and agree on canonical fork/history hashes. Retain VERIFIED / RESOLVED.

Delta and binding. No node delta. The fresh review verifies the unchanged call sites and source-to-release identities; no native test was rerun. Canonical genesis evidence remains the retained, hash-bound configuration record, with activation at 12,186,213.

Evidence. INHERITED_EXECUTED_LOG: `evidence/protocol/retained-evidence-checks.json#native_inherited` — Hash-checked final independent native suite and four-validator E2E on 51d92f1; assertions inspected in retained fixtures. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Current enforcement paths and exact release-equivalent source. FRESH_READ_ONLY_PRODUCTION: `evidence/protocol/public-chain-evidence-summary.json (raw RPC records protected)` — Both XGR endpoints report v3.4.0; numeric canonical fork/history checks. INHERITED_CONFIGURATION: `../2026-10-27-xita-direct-bls-delta-v3.1.0/evidence-public.zip!/evidence/canonical-genesis-evidence.json` — Archived authorized canonical genesis/configuration evidence; no third repository accessed.

Current source. xgr-node/state/executor.go:193-202; xgr-node/state/executor.go:740-746; xgr-node/state/executor.go:828-844; xgr-node/consensus/ibft/security_accounting.go:21-61; xgr-node/consensus/ibft/verifier.go:90-105; xgr-node/consensus/ibft/ibft.go:480-492; xgr-node/consensus/ibft/ibft.go:630-643; xgr-node/blockchain/security_accounting.go:12-50.

Limits. The 1,081 independent test/subtest pass events and 479 upstream events overlap conceptually and are not distinct exploit counts. The four-validator E2E did not inject invalid network proposals or prove every installed host configuration. RPC version strings identify observed software behavior, not each host binary digest. These limits do not reclassify the verified source fix as a current High or produce a NO-GO by themselves.

Minimal action. Maintain the established fork configuration and release identity controls. Retain the rejection/accounting regressions and continue ordinary rollout/configuration reconciliation. No new corrective product change is required for the original condition.

Confidence. High.

F-02 - Transaction-original storage and refund accounting

RESOLVED / P1 / VERIFIED · SCHLIESSBAR.

Original cause. The original storage snapshot could retain a previous transaction’s original-slot state inside one block. Refund subtraction could wrap an unsigned counter. This changed transaction gas/refund accounting; the historic refund cap limited the demonstrated effect and did not establish arbitrary minting.

Current assessment. beginTransaction captures the transaction-local original state before execution. Checked refund additions/subtractions record an invariant failure, and the executor propagates that failure instead of paying a wrapped refund. The retained active matrix compares 972 nested storage cases with a fresh committed-state reference, while 48 finite preactivation vectors preserve the earlier behavior. An expected failing baseline case confirms that the independent harness distinguishes the old defect from the candidate. Retain VERIFIED / RESOLVED and SCHLIESSBAR.

Delta and binding. The node baseline and target are the same commit. Current source is byte-identical to the tested v3.1.0 candidate, including transaction originals, state copying and refund-error propagation.

Evidence. INHERITED_EXECUTED_LOG: `evidence/protocol/retained-evidence-checks.json#native_inherited` — Final native log, baseline replay and expected baseline failure verified by SHA256 and parsed action counts. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Current state/txn/executor implementation matches the retained candidate.

Current source. xgr-node/state/executor.go:625-628; xgr-node/state/executor.go:828-831; xgr-node/state/txn.go:454-490; xgr-node/state/txn.go:514-548; xgr-node/state/state.go:124-142.

Limits. The finite vectors are not an exhaustive EVM equivalence proof. No fresh Go run, network transaction or production host inspection was performed in this audit. Per-host identity remains an operational evidence limit, not an unresolved source defect.

Minimal action. Preserve fork-gated transaction-local accounting and the retained differential/rejection regressions. No further fix is needed for the demonstrated original cause.

Confidence. High.

F-03 - Expensive gossip work lacks complete admission bounds

Medium / P1 / OPEN · OFFEN.

Original cause. Peer checkpoint votes and quorum hints can trigger full source verification before sufficiently cheap member/signature admission. Gossip delivery starts a goroutine for each message. Governance proposal admission lacks a global count/disk limit and an upper bound on accepted future expiry.

Current assessment. The 128 KiB envelope cap and selected completed-quorum throttling are useful, but they do not bound the aggregate work of the checkpoint-vote and request branches. In acceptILNCheckpointVote, remote evidence verification precedes signer index, eligibility and signature checks. The quorum-request branch reaches source reads and the common signer. Governance state can accumulate otherwise admissible long-lived proposals. The residual concern is validator-host resource availability; no source-authentication bypass or actual IBFT halt is established.

Delta and binding. No node changes address these admission paths. New UI/observer activity does not alter their source-level bounds, and the transfer caller remains unable to supply trusted evidence directly.

Evidence. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Current ordering and missing global admission bounds re-inspected. INHERITED_TEST_CONTEXT: `evidence/protocol/retained-evidence-checks.json#v30_inherited` — Standard/race suites support ordinary paths, not saturation resistance. HISTORICAL_RECONCILIATION: `historical-findings-matrix.csv` — Both 24:M-05 and 25:M-05 retain the same underlying resource-isolation requirement.

Current source. xgr-node/network/gossip.go:108-122; xgr-node/interchain/runtime/worker.go:830-880; xgr-node/interchain/runtime/iln_checkpoint.go:167-201; xgr-node/interchain/runtime/iln_quorum_request.go:211-238; xgr-node/interchain/runtime/governance.go:201-240.

Limits. No public flood, resource-exhaustion experiment or production consensus outage was attempted. Per-call deadlines constrain individual reads but are not an aggregate concurrency or memory bound. Severity remains Medium rather than assuming consensus failure.

Minimal action. Add cheap bounded admission and in-flight deduplication before remote reads, followed by bounded global/per-peer concurrency and fair service. Bound governance proposal count, storage and future lease. Keep complete source verification before signing and validate consensus continuity under controlled load.

Confidence. High.

Historical occurrence mapping. 2026-10-24/M-05, 2026-10-25/M-05.

F-04 - Shared observer retry fairness and failure isolation

Medium / P1 / OPEN · OFFEN.

Original cause. The earlier shared-cursor defect let one failed operation stall sibling routes. Durable retry storage mitigated that original failure, but retry service always starts from the same route ordering and consumes a fixed source-wide budget; corrupt or full retry storage can still affect the source group.

Current assessment. A source poll serves at most 24 due retry records, at most two per route, in fixed route order. The retained controlled test models recurring eligible failures across 13 routes and demonstrates that the late route receives no service while earlier backlogs consume the budget. Queue admission is durable and rejects conflicting identity or capacity overflow; work is retained instead of silently dropped. Corrupt-record and capacity errors still propagate to source-wide progress. This is a conditional availability defect, not a demonstrated stall in the currently small route set.

Delta and binding. No changes to node observer scheduling or journals. The current source exactly matches the retained v3.1.0 negative reproduction and the v3.0 durability regression paths.

Evidence. INHERITED_EXECUTED_NEGATIVE: `evidence/protocol/retained-evidence-checks.json#protocol_inherited` — Actual bounded retry-fairness reproduction on current node source; passing means the adverse condition was reproduced. INHERITED_EXECUTED_LOG: `evidence/protocol/retained-evidence-checks.json#v30_inherited` — Durable dedup/reverification and corrupt-journal rejection pass in retained standard and race logs. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Retry source and related test paths unchanged.

Current source. xgr-node/interchain/runtime/iln_observer_retry.go:17-25; xgr-node/interchain/runtime/iln_observer_retry.go:74-105; xgr-node/interchain/runtime/iln_observer_retry.go:144-199; xgr-node/interchain/runtime/iln_observer_worker.go:128-162; xgr-node/interchain/runtime/iln_observer_worker.go:180-210.

Limits. The retained test uses a temporary-failure signing stub and local files, not a hostile production network. No disk power-loss test or currently deployed route stall is claimed. Route-hint fairness under M-06 is a different queue and remains closed.

Minimal action. Persist or otherwise maintain a fair rotating route cursor, preserve original evidence when quarantining corruption, and expose backlog age/capacity. Test that a late healthy route progresses through sustained earlier failures and that capacity pressure remains isolated.

Confidence. High.

Historical occurrence mapping. 2026-10-25/N-01.

F-05 - External source witnesses retain correlated-provider trust

Medium / P1 / OPEN · **OFFEN**.

Original cause. External-source signing historically depended on a provider view that honest BLS validators could share. Requiring two labelled operators removed the single-counted-witness failure mode but left correlated or colluding providers and their upstreams inside the trust boundary.

Current assessment. Each witness supplies the complete receipt/message/route/fee view from one endpoint; the comparison requires the exact source block hash and all relevant operation fields. Duplicate URLs with the same operator label do not add votes. The first matching pair of different labels succeeds even if an earlier successful witness disagreed. The retained injected-reader test confirms that behavior. Labels and endpoint reachability cannot establish physical upstream independence. XGR source evidence is read from committed local IBFT state; the external provider residual applies to external chains. Retain Medium OPEN, with the historic High-to-Medium reassessment preserved.

Delta and binding. The witness algorithm and configured finality model are unchanged. Fresh successful RPC and safe-head/canonical-hash observations support current reachability and identity, not resistance to correlated fabrication.

Evidence. INHERITED_EXECUTED_NEGATIVE: `evidence/protocol/retained-evidence-checks.json#protocol_inherited` — Matching-pair-after-earlier-disagreement injected-reader test on the unchanged source.

SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Complete per-endpoint binding, deduplicated operator IDs and exact witness comparison. FRESH_READ_ONLY_PRODUCTION: `evidence/protocol/public-chain-evidence-summary.json (raw RPC records protected)` — Endpoint reachability and numeric canonical/safe-head consistency observations. HISTORICAL_RECONCILIATION: `historical-findings-matrix.csv` — 24:H-01 and 25:H-01 original conditions and mitigating two-witness design retained.

Current source. xgr-node/interchain/evm/rpc_evidence_quorum.go:31-89; xgr-node/interchain/evm/rpc_evidence_quorum.go:92-114; xgr-node/interchain/config.go:18-40; xgr-node/interchain/runtime/iln_direct_signing.go:95-127.

Limits. The injected reader does not construct fabricated real RPC receipts or a live unauthorized quorum. Infrastructure independence was not attested. A single faulty independently counted witness is insufficient; two correlated counted labels remain the relevant prerequisite. The audit does not invent operator acceptance of the external-chain safe-finality model.

Minimal action. Document and verify actual primary/fallback upstream independence, monitor disagreements, and keep fail-closed complete evidence checks. Treat a newly discovered common controlling upstream as a reason to reassess the configured witness set, without redesigning Direct-BLS solely because the dependency exists.

Confidence. High.

Historical occurrence mapping. 2026-10-24/H-01, 2026-10-25/H-01.

F-06 - Restricted-role reads and readiness omit new quote/monitor dependencies

Original cause and previous correction.

The v3.0.0 finding was a missing SELECT privilege used by the aggregate quote-capacity query: the isolated quote writer could insert quote evidence but could not read transfer operations, while readiness omitted the same dependency. The protected v3.1.0 record identifies corrective PR342, commit `c2606cd834c55d4117209be715f5b044b580f736`, and actual PostgreSQL evidence that granting reads on operations/resolutions fixed the original path without allowing updates to protected records. The corrected v3.1.0 public register therefore marked F-06 VERIFIED.

Those earlier operations/resolutions grants remain in the frozen migration and readiness query. They were not removed. The new regression is that the newly added persistent wallet admission SELECT reads `xita_sponsor_quote_intents`, but the migration and readiness contract were not expanded with it. The same failure class now affects the appended overtaken-obligations monitor read. Treating A-Q1 as a new independent issue while leaving F-06 closed would hide the recurrence and duplicate the underlying installation-boundary finding.

Current source and evidence.

- `services/managed-relay/tax-evidence.mjs:101-112`: the new advisory-lock-protected wallet count reads intents.
- `services/indexer/sql/010_wallet_aware_sponsor_commitments.sql:50-55` and `011_quote_writer_runtime_grants.sql:25-36`: isolated writer gets INSERT but no SELECT on intents; verification also omits it.
- `services/managed-relay/server.mjs:84-105`: paid-quote readiness can return all predicates true while the admission query is denied.
- `services/managed-relay/sponsor-obligation-audit.mjs:99,113-124` and `services/indexer/sql/014_sponsor_overtaken_obligations.sql:14-22`: the read-only status role has no grant on the new table, so the complete report throws.

Sealed Phase A `Protected: quote/postgres-reproducible.log` and `quote/postgres-reproducible.json` proves both failures with real PostgreSQL 16.15 after the complete canonical migration sequence, including 011 and 012. Under the isolated quote role every readiness predicate is true, actual admission rejects with SQLSTATE 42501, and the transaction leaves zero quote evidence rows. Under the status reader, the actual monitor rejects with SQLSTATE 42501. A failed CLI is detectable and is not described as a falsely clean monitor result.

Disposition and operational qualification.

Medium / OPEN / OFFEN; confidence High. The affected class is supported restricted-role deployment. A consolidated writer with the missing SELECT already granted can operate; no claim is made that all installed hosts are affected. The coordinating auditor's current read-only health response advertises paidQuoteReady and sponsorship availability. This is useful live service evidence but cannot establish the missing actual-role check: precisely that readiness query is shown to be insufficient in a supported role configuration. No production role inventory was available.

The narrow fix remains a migration/readiness correction, not a change to transfer protocol or user signatures. Grant only SELECT on intents to the actual approved signer, and SELECT on overtaken obligations to the actual status reader. Validate those dependencies in readiness and CI using real non-superuser roles. Do not grant UPDATE or DELETE on immutable commitments as a workaround.

F-07 - Sponsor reservation can strand the sender nonce after interruption

VERIFIED / RESOLVED; current severity None; confidence High.

Original technical cause. The reservation committed before a signed transaction or durable hash existed. Restart only selected submitted rows with a hash, so a crash left an unrecoverable reserved nonce blocking later grants.

Relevant implemented changes. decf6d2f6085eac7a23a1377d975a31605855aa7 signs and verifies original bytes before durable reservation; f06f05f758764ac32dcc1b3718f89bd56cc520a0 adds prepared journal; c8960f129770fa724d2efd773123a3e72de791a6 reconciles prepared reserved rows; 81535e27081c0528e7c017a5bb0ce96c000b7a6f schedules retained prepared rows; 85973bd9c8ab35cdc33ecb5b6fd919468eacdac9 gates replay on native delivery evidence.

Independent verification and provenance. Fresh: exact-byte restart mock, consumed-nonce hold, real PostgreSQL committed grant+prepared record, competing-nonce serialization and rollback after injected prepared insertion failure. Inherited: original pre-broadcast crash/nonce-wedge demonstration from v3.0 and hash-verified protected v3.1 service traces.

Current assessment and limits. The original missing-byte/hash defect is prevented for newly created grants. Pre-upgrade orphan rows cannot acquire a trustworthy signed identity retroactively and need controlled operator reconciliation. A separate new timeout/effect-boundary defect A-SP-01 remains open; closure here does not approve the complete sponsor subsystem.

Narrow next action. Do not remove nonce uniqueness or re-sign an uncertain legacy payment. Preserve pre-upgrade obligations, reconcile their exact transaction identity under operator control. Address A-SP-01 separately with effect-safe deadlines.

Frozen source references: `services/managed-relay/gas-sponsor.mjs:252-299`, `services/managed-relay/gas-sponsor.mjs:330-370`, `services/managed-relay/gas-sponsor.mjs:460-504`, `services/managed-relay/gas-sponsor.mjs:514-581`, `services/indexer/sql/013_sponsor_prepared_tx.sql:3-20`, `services/indexer/sql/004_sponsor_grants.sql:4-18`.

Evidence references: `../existing-gas-unit-direct.log`, `../adversarial-recovery-direct.log`, `../postgres-adversarial.log`, `../../root/test-logs/services__managed-relay__sponsor-obligation-audit.pg.test.mjs.log`,

historical/2026-10-27-xita-direct-bls-final-v3.0.0/sponsorship/auditor-fault-tests.tap, historical/2026-10-27-xita-direct-bls-final-v3.0.0/sponsorship/sql-permissions.log.

F-08 - One grant RPC failure can block all-chain sponsorship

PARTIALLY_MITIGATED; current severity Medium; confidence High.

Original technical cause. v3.0 had escaping submitted-grant errors and oldest-only windows; v3.1 fixed that helper but left earlier serial expiry and reserve reads able to block all later stages.

Relevant implemented changes. 38bd242c6ad8efca1edefceea962af543b715c53 bounds reserve/expiry reads, partitions expiry by source and retains failures; Prepared recovery changes preserve per-row reconciliation catches but introduce a separate late-effect defect.

Independent verification and provenance. Fresh tests show healthy grant reconciliation after another-chain RPC failure/timeout and healthy reserve monitoring after a stalled peer. Current source proves bounded/partitioned expiry. Inherited v3.1 controlled-promise traces establish the now-repaired earlier-stage blockers. Remaining fresh-candidate caller and event-listener child are statically traced; no new live outage was induced.

Current assessment and limits. Fresh candidates remain globally oldest-first and serial, with unbounded provider preflight awaits and up to 30 seconds waiting per transaction. A slow candidate can prevent later healthy-chain candidates until the timer child dies; event-triggered child invocation lacks that timer deadline. Errors are caught once they return, not bounded during pending reads.

Narrow next action. Use bounded read-only preflight and per-chain fair scheduling for fresh candidates; keep payout effects outside uncancellable race callbacks and keep sweep work inside its service time budget. Add a controlled-promise candidate test proving healthy independent-chain progress.

Frozen source references: services/managed-relay/gas-sponsor.mjs:506-585, services/managed-relay/gas-sponsor.mjs:587-620, services/managed-relay/gas-sponsor.mjs:678-725, services/managed-relay/gas-sponsor.mjs:771-805, services/managed-relay/gas-sponsor.mjs:216-279, services/managed-relay/sponsor-event-listener.mjs:10-29, services/managed-relay/xita-gas-sponsor.service.example:10-18.

Evidence references: ../existing-gas-unit-direct.log, ../phase-a.md, historical/2026-10-27-xita-direct-bls-final-v3.0.0/sponsorship/auditor-fault-tests.tap, protected-v3.1/services/records/phaseB-services.json, protected-v3.1/services/independent/independent-services.tap.

F-09 - Mailbox completion can conceal a pending native-principal claim

Medium / P1 / OPEN · OFFEN.

Original cause. Authenticated native delivery can fail to pay recipient code within the router's 30,000-gas allowance. The router reserves a backed pending balance and returns successfully, so Mailbox delivery does not necessarily mean native principal reached the beneficiary. The presentation layer equates these states.

Current assessment. The contract still checks unreserved balance before payment, records pendingNativeXGR only after a failed payout, and permits only the original beneficiary to withdraw to an alternative recipient. Replay and backing controls remain intact. Fresh composition of the current indexedTransferRow, deriveTransferFlow and describeTokenJourney modules, with valid finality evidence and a supplied pending balance, still reports Transfer complete, no further wallet action, and XGR unlocked. A smart wallet with an authorized execution path may recover; an arbitrary recipient contract cannot be assumed able to call the withdrawal function.

Delta and binding. transfer-status-flow.js changed in this delta, but its completed-native-payout projection is still claim-unaware. The native router, token-journey presentation and index row conversion are byte-identical to the earlier audited versions. The fresh five-assertion local check reproduces the original condition at the current Interchain HEAD.

Evidence. FRESH_LOCAL_CHECK: `evidence/protocol/f09-presentation-result.json` — Five assertions against actual current presentation/read-model modules with finalityVerified=true; adverse condition reproduced. INHERITED_EXECUTED_LOG: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/deferred-native-ui-summary.json` — Real Mailbox/native-router isolated integration with mocked ISM established backed pending principal, unchanged recipient balance, replay rejection and authorized recovery. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Contract and claim-reservation behavior unchanged; changed caller rechecked.

Current source. xgr-interchain/contracts/XETAGuardedNativeWarpRouter.sol:25-38; xgr-interchain/contracts/XETAGuardedNativeWarpRouter.sol:68-85; xgr-interchain/services/indexer/transfer-index-store.mjs:46-67; xgr-interchain/apps/web/transfer-status-flow.js:17-40; xgr-interchain/apps/web/transfer-status-flow.js:119-145; xgr-interchain/apps/web/transfer-token-journey.js:63-86.

Limits. No fresh Solidity execution, browser E2E, funded smart wallet or production transaction. The inherited integration mocked authentication to isolate payout behavior and is not a BLS-bypass test. Restricting supported recipients reduces operational exposure but does not remove the general source condition.

Minimal action. Before initiation enforce the stated supported native-recipient policy where required, and distinguish confirmed Mailbox delivery from deferred principal. Surface existing beneficiary-authorized recovery accurately for supported wallets. Do not invent an additional mandatory user signature or sponsorship transaction; the existing withdrawal is an exceptional claim path.

Confidence. High.

Historical occurrence mapping. 2026-10-25/N-09.

F-10 - Authorized ownership transfer can collapse service/admin separation

Low / P2 / OPEN.

Original cause. The gateway constructor and service-wallet setter enforce different service and recovery-admin addresses, while inherited two-step ownership nomination/acceptance do not enforce the same invariant, including the pending-owner rotation order.

Current assessment. The gateway still inherits the ownership transition and only overrides renunciation. A legitimate owner can nominate the service wallet, or nominate a future owner before changing the service wallet to that pending owner. Acceptance collapses the independent recovery role. This requires authorized administrative action and does not give an unprivileged actor control or permission to sweep principal. Fresh XGR reads show distinct roles; the earlier three-chain distinct-role observation is retained as historical evidence.

Delta and binding. Gateway Solidity and dependency declaration are unchanged from the prior assessments. The retained isolated ownership-transition test remains applicable to the identical contract and declared OpenZeppelin dependency; no fresh dependency installation or contract execution is claimed.

Evidence. INHERITED_EXECUTED_LOG: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/forge-independent-final.log` — Actual isolated inherited ownership transition reproduced role collapse. SOURCE_PROOF:

evidence/protocol/phase-b-source-identity.json — Gateway source and dependency declaration unchanged. FRESH_READ_ONLY_PRODUCTION: ../registry-live-checks.json — Current XGR owner/service addresses are distinct; Base/Arbitrum supplemental reads were unavailable in this pass.

Current source. xgr-interchain/contracts/XITAExecutionGateway.sol:130-161; xgr-interchain/vendor/package.json:1-20.

Limits. The OpenZeppelin dependency was not reinstalled or newly compiled in Phase B. Current observations do not show role collapse. The risk requires the owner's participation or error, so the Low classification is retained.

Minimal action. Keep independent key custody and check both current and pending ownership before role rotations. In a future contract revision enforce inequality at nomination, acceptance and setServiceWallet, covering either transition order.

Confidence. High.

Historical occurrence mapping. 2026-10-24/L-03, 2026-10-25/L-03.

F-11 - Membership authorizations omit the exact registry deployment

Medium / P1 / ACCEPTED_RISK · OFFEN.

Original cause. Membership payloads bind chain/domain, expected set, expiry, action and keys but omit the exact registry deployment address. Equivalent simultaneously active deployments can therefore accept the same valid membership authorization.

Current assessment. The omission is explicit in both node configuration commentary and Solidity encoding. The pre-existing decision accepts this residual only while exactly one selected registry per chain is active. Transfer authorizations separately bind destination registry and ISM, so this is not an arbitrary transfer-message replay. The current manifests select one registry per chain, but do not prove that no unlisted equivalent contract exists. Retain ACCEPTED_RISK as the historical architectural disposition and OFFEN for the management category: acceptance does not eliminate the source condition.

Delta and binding. No contract, wire-format or node-policy change. No new blanket operator risk acceptance is inferred from an unchanged tree or a successful transfer.

Evidence. INHERITED_EXECUTED_LOG: ../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/forge-independent-final.log — Matching-registry payload/state-machine test used an explicit mock verifier to isolate the domain omission. SOURCE_PROOF: evidence/protocol/phase-b-source-identity.json — Intentional encoding and documented pre-existing invariant remain unchanged. FRESH_READ_ONLY_PRODUCTION: evidence/protocol/deployment-identity-checks.json — Receipt-pinned configured contract identities remain consistent; not a proof about all possible unlisted deployments.

Current source. xgr-interchain/contracts/XGRInterchainValidatorRegistryV3.sol:376-460; xgr-interchain/contracts/XITADirectProtocol.sol:42-49; xgr-node/interchain/config.go:21-31.

Limits. The mocked verifier test establishes identical payload/state transitions, not a new cryptographic forgery. The operating invariant is an external deployment/control assumption. No unlisted-registry census or new acceptance authorization was performed.

Minimal action. Maintain the documented single-active-registry invariant and explicit receipt-pinned configuration. Reopen domain design before overlapping equivalent migrations; use a deliberately versioned address-bound membership scheme if that invariant changes.

Confidence. High.

F-12 - Minimum validator committee size remains an operating rule

Low / P1 / OPEN.

Original cause. Bootstrap requires a nonempty committee rather than a minimum of three, and authorized membership removal stops only at one remaining member. The correct ceil(2n/3) threshold consequently becomes one signature for a one-member set.

Current assessment. The original governance-policy condition remains. It is an authorized weakening of fault tolerance, not a way for an outsider to bypass the bitmap or quorum checks. Fresh XGR registry reads show three members and threshold two. The earlier all-three-chain observation remains historical and is not silently promoted into a new Base/Arbitrum committee observation. Key/operator independence remains an operating requirement.

Delta and binding. No registry contract or node membership delta; the retained isolated single-member policy test applies to unchanged Solidity.

Evidence. INHERITED_EXECUTED_LOG: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/forge-independent-final.log` — Single-validator bootstrap and one-signer quorum policy test with mocked cryptography. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Threshold and authorized minimum set size unchanged. FRESH_READ_ONLY_PRODUCTION: `../registry-live-checks.json` — XGR: three active members and threshold two.

Current source. xgr-interchain/contracts/XGRInterchainValidatorRegistryV3.sol:122-135; xgr-interchain/contracts/XGRInterchainValidatorRegistryV3.sol:306-335; xgr-interchain/contracts/XGRInterchainValidatorRegistryV3.sol:630-636.

Limits. Independent physical operators and key custody were not attested. No current quorum reduction is observed. Mocked policy tests do not replace the separate real BLS verifier tests. A permanent quorum loss has no administrator bypass.

Minimal action. Monitor the assessed minimum of three independently operated active keys and current-set re-attestation continuity. Introduce an on-chain minimum only as an explicit governance/migration decision; current operating controls remain proportionate to this Low risk.

Confidence. High.

F-13 - Wallet proof calldata is not fully bound to selected intent

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: The browser validates metadata, destination, selector and zero native value but does not decode process message bytes and bind their hash to the selected source message.

Delta and regression assessment: transfer-actions.js gains unsigned dynamic gas preview before TX1; its destination proof check remains unchanged in substance and is not strengthened by spendable status.

Verification: Fresh source trace of metadata/selector checks and lack of message-data hash comparison; existing transfer-actions30/30 and native codec4/4 pass; historical v3.0 F13 and24/25 L01 retained.

Impact, existing mitigation and limits: A compromised proof service may induce gas payment for another independently valid message. Destination signature, route and replay checks still enforce principal authorization. No arbitrary mint or redirection demonstrated.

Minimal remediation: Decode process arguments and validate the actual Direct-BLS message/authorization identity before eth_sendTransaction; add adversarial substituted-valid-message test.

Exact frozen-source references: `apps/web/transfer-actions.js:680-708`; `services/indexer/transfer-recovery.mjs:65-87`; `runtime/native-relayer/xita-direct-codec.mjs`.

F-14 - Regression fixtures and CI discovery drift from the current product

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: Some negative tests assume obsolete behavior and CI uses manually enumerated test lists, omitting existing and newly added suites.

Delta and regression assessment: No CI workflow delta. New gas profile and gas observer suites are absent from explicit Validate discovery; sponsor expiry mock retains an old query-prefix assumption.

Verification: Fresh rpc-read9/10 with one contradictory pinned eth_call assertion; both test and implementation blobs identical at baseline. Original failed log retained. Other audited assertion results not represented as total repository green.

Impact, existing mitigation and limits: A green selected workflow cannot establish comprehensive negative coverage. The disclosed failure is a test contradiction, not a current authorization bypass.

Minimal remediation: Correct only expectations contradicted by intentional documented behavior; add new test files to CI discovery; ensure expiry mock reaches WITH due AS; preserve negative assertions for forbidden writes.

Exact frozen-source references: `.github/workflows/validate.yml:97-160`; `services/indexer/rpc-read.test.mjs:37-52`; `services/indexer/rpc-read.test.mjs:137-149`; `services/managed-relay/gas-sponsor.test.mjs:328`.

F-15 - Production sponsorship and installation readiness remain unproven

OPEN; current severity Informational; confidence High.

Original technical cause. The old read-only observation reported sponsoring enabled but unavailable; installed service, role, journal and build identity were not demonstrated. It was not an identified source-level exploitation path.

Relevant implemented changes. Fresh public health observation on 2026-10-29 reports paidQuoteReady=true, enabled=true, available=true for all three configured chains; F06 remains an independently reproduced source/migration readiness gap; it must not be inferred as installed solely from a green health flag.

Independent verification and provenance. Fresh read-only HTTP 200 at 2026-10-29T08:55:03.799647Z supersedes the old unavailable status. Fresh restricted-role tests demonstrate health dependency gaps locally. Installed-role, payout-history and service-source attestation remain unobserved; no production payment was requested or made.

Current assessment and limits. Availability is now affirmatively reported. Exact installed privilege coverage and complete paid-path recovery cannot be inferred from the endpoint. This is an operational assurance gap, not a demonstrated new vulnerability or proof that production is down.

Narrow next action. Request existing sanitized service revision/migration/role checks, aggregate aged journal status and already-existing representative paid one-/two-hop evidence when deciding installed readiness. Do not require a new Mainnet payment or lower core release status solely because an individual host attestation is absent.

Frozen source references: `services/managed-relay/server.mjs:84-106`, `services/managed-relay/server.mjs:384-395`.

Evidence references: `../../root/public-sponsor-health.json`, `historical/2026-10-27-xita-direct-bls-final-v3.0.0/phase-a/sponsorship.md`, `../postgres-adversarial.log`, `../../quote/postgres-adversarial.log`.

F-16 - Expiry-release evidence trusts one RPC without a canonical reread

VERIFIED / RESOLVED; current severity None; confidence High.

Original technical cause. One finalized/committed head plus a number-tagged nonce call could append expired-unused without independent agreement or a post-call hash reread, removing an actually owed liability from accounting.

Relevant implemented changes. 38bd242c6ad8efca1edefceea962af543b715c53 adds distinct-host witness, chain check, same-height hash/nonce agreement and repeated canonical hash checks before resolution insertion.

Independent verification and provenance. Fresh actual-helper tests exercise matching witnesses, hash disagreement, nonce disagreement, changing canonical hash, absent second witness and lagging finalized witness. Inherited archive shows original single-read acceptance. The full caller/DB release boundary was independently reviewed in Phase A.

Current assessment and limits. Distinct endpoint hosts do not prove independent upstream ownership; correlated false evidence remains a declared trust assumption shared with external-RPC risk. Honest absent/lagging/contradictory data retains obligations. XGR uses its documented committed native policy. No production release or treasury sufficiency is inferred.

Narrow next action. Maintain independent RPC operators and monitor retained-resolution backlog. Preserve fail-closed behavior and add a functioning caller-level outage regression for the obsolete N-06 query stub. No further code correction is required to eliminate the original single-view/no-reread condition.

Frozen source references: `services/managed-relay/gas-sponsor.mjs:107-122`, `services/managed-relay/gas-sponsor.mjs:628-673`, `services/managed-relay/gas-sponsor.mjs:678-725`, `services/managed-relay/tax-evidence.mjs:147-162`.

Evidence references: `../existing-gas-unit-direct.log`, `historical/2026-10-27-xita-direct-bls-final-v3.0.0/sponsorship/auditor-fault-tests.tap`, `protected-v3.1/services/records/phaseB-services.json`.

F-17 - Unpaid payer aliases still occupy finite sponsor admission capacity

Original cause.

Historical 25:N-06 and F-17 describe prepayment capacity occupation. A public request can obtain a signed quote whose positive sponsorship promises reserve real treasury/daily budget before TX1 payment. When unused commitments consume the configured capacity, an honest user can be denied a new optional sponsored quote. This is an admission-availability risk, not authorization to receive gas without a verified paid source event.

Delta and current behavior.

Commit `69e4e2ff0bee9e81ab8bc570866f7966b73c5283`, included through the frozen history, adds a transaction-scoped per-payer lock and count at `tax-evidence.mjs:97-112`. The count is persistent across signer processes and enforces at most two unexpired unresolved intents for that payer. The sealed real-PostgreSQL concurrency case admits exactly two of three simultaneous same-wallet requests and rolls back the third. This is a substantive correction to the former in-memory-only bound.

The anonymous identity boundary remains. `server.mjs:360-376` applies four attempts/IP, two/payer and 120/global per minute; the endpoint accepts a payer address and does not require another wallet

signature. `tax-evidence.mjs:147-180` still includes all unsettled positive commitments in capacity, correctly preserving potential paid obligations. A different payer has a different durable admission lock and count. Source quote expiration changes eligibility for new requests, not financial liability.

`gas-sponsor.mjs:682-696` selects unresolved quotes only after five minutes beyond quote expiry, with at most 12 per source chain and 80 total. The strengthened verifier at 628-673 requires appropriate finalized evidence, including two external witnesses and pinned hash/nonce agreement. Its separate finalized-head timestamp grace is two minutes; the SQL eligibility threshold remains five minutes. None of these values is a guaranteed release deadline: finality, RPC uncertainty and backlog can extend it. Do not release an uncertain promise merely to satisfy a capacity target.

New negative reproduction.

`Protected: quote/phase-b/historical-rechecks.test.mjs` invokes the **actual** rate limiter and the **actual** `saveQuoteEvidence` against the isolated database. Three valid distinct payer fixtures within the four-request IP allowance occupy a small positive, fully funded configured daily budget. A fourth payer passes the rate limiter but its new quote is refused by aggregate capacity. The database contains three quote intents and commitments, zero paid transfer operations and zero sponsor grants. The policy fixture uses a positive reserve; it is intentionally scaled for a deterministic local boundary and is not a claim about production amounts or saturation rates. No transaction, payout, remote exhaustion or user signature occurred. Detailed result: `Protected: quote/phase-b/historical-rechecks-final.log/json`, two tests total including F-24, both pass.

Disposition and remedy.

Medium / PARTIALLY_MITIGATED / OFFEN; confidence High. Mark the durable same-wallet guard as verified, but do not present it as elimination of payer-alias or distributed demand pressure. The risk is bounded by finite admission/rate and treasury policies; it does not by itself require a NO-GO for principal transfers or necessarily for a controlled sponsored service. The audit does not accept availability loss for the operator.

Use measured demand to bound provisional admission globally/per network and add suitable fair admission/abuse controls while retaining all paid/uncertain obligations. Keep rejection visible and retryable. No additional user signature, onchain reservation transaction or invasive architecture change is mandated. A closure claim must specify the actual bounded availability guarantee and evidence, rather than infer one from a per-wallet count.

F-18 - Conservative daily-limit accounting can count a liability twice

OPEN; current severity Low; confidence High.

Original technical cause. Outstanding commitments exclude only confirmed payouts while issued-today includes every recent grant status. The daily arithmetic adds these overlapping sets.

Relevant implemented changes. No correction to the overlapping accounting predicates; sponsor-funding.mjs is byte-identical to baseline; Other quote admission changes do not remove the same-amount overlap.

Independent verification and provenance. Fresh Phase B arithmetic proof with actual sponsorCapacityCovered: outstanding40+issued40+new10 exceeds cap80 at90 although unique exposure is50; zero-overlap control accepts. The two SQL predicates were statically rechecked. Historical assessment was static; no live financial volume is asserted.

Current assessment and limits. In-flight or uncertain payouts can conservatively reduce quote availability. This is under-admission, not a demonstration of insufficient backing, unauthorized money creation or principal loss.

Narrow next action. Define mutually exclusive confirmed-spend and unsettled-obligation sets, keeping every uncertain grant represented exactly once. Add real-schema tests for

reserved/submitted/confirmed/needs-review and rolling-window boundaries before changing financial arithmetic.

Frozen source references: `services/managed-relay/tax-evidence.mjs:147-180`, `services/managed-relay/sponsor-funding.mjs:27-53`.

Evidence references: `f18-accounting.log`, `f18-accounting.test.mjs`, `control-hash-comparison.json`, `protected-v3.1/services/records/phaseB-services.json`.

F-19 - Paid grant lifecycle can remain unresolved after early delivery or shutdown

PARTIALLY_MITIGATED; current severity Medium; confidence High.

Original technical cause. Every stage requires the original parent undelivered; permissionless external completion can make an owed grant ineligible. The global disabled switch stops existing servicing as well as new promises.

Relevant implemented changes. 2c6690953966830f390ce397269cf4b2b1077e45 adds append-only overtaken obligation ledger; 5332409123e68c32abcb1d5b6e2cdcffe2c3bc2c records quote-bound paid delivered obligations; 0456d6c6324ed0af91852e1b8d682973c9877ea5 exposes durable unresolved liabilities in aggregate diagnostics; No implemented settlement/outcome policy or separate stop-new/drain-old worker mode.

Independent verification and provenance. Fresh real-schema repository tests verify overtaken insertion is durable/idempotent, wrong sponsor/chain/recipient/amount cannot masquerade as confirmation, two-hop stages remain separately owed, and disabled-state monitoring does not settle promises. Fresh restricted-reader test shows the new F06 privilege regression. Historical traces demonstrate delivered-stage rejection and disabled worker early return; unchanged predicates are hash-checked.

Current assessment and limits. Liabilities now have better durable evidence but remain neither fulfilled nor settled; they can continue consuming capacity. The emergency/global stop still returns before servicing. The register is not a refund, debt waiver or operator-authorized risk acceptance.

Narrow next action. Keep obligations, original transaction identities and nonce reservations intact. Separate stopping new quote admissions from read/reconciliation of existing grants; document and implement a narrowly authorized outcome record for externally completed promises. Use operator review, not automatic post-delivery gas transfers or deletion. Fix read-only monitor privilege coverage through F06.

Frozen source references: `services/managed-relay/gas-sponsor.mjs:29-42`, `services/managed-relay/gas-sponsor.mjs:125-159`, `services/managed-relay/gas-sponsor.mjs:729-758`, `services/managed-relay/gas-sponsor.mjs:771-805`, `services/managed-relay/sponsor-obligation-audit.mjs:65-109`, `services/managed-relay/server.mjs:406-445`, `services/indexer/sql/014_sponsor_overtaken_obligations.sql:4-23`.

Evidence references:
`../../root/test-logs/services__managed-relay__sponsor-obligation-audit.pg.test.mjs.log`, `../postgres-adversarial.log`, `../existing-gas-unit-direct.log`, `historical/2026-10-27-xita-direct-bls-final-v3.0.0/sponsorship/auditor-fault-tests.tap`, `protected-v3.1/services/records/phaseB-services.json`.

F-20 - Pending recovery work can be removed before durable replacement

Medium / P1 / OPEN · OFFEN.

Original cause. Persisted votes can be removed when their route is temporarily missing or when a set changes, before successor signing succeeds. Old undelivered attestations can also be pruned after evidence is judged regenerable without persisting a replacement job.

Current assessment. The missing-route branch deletes immediately. The rotated-set branch removes the old vote before calling signDirectILNMessage; a temporary error leaves only a log. The storage-pruning check reconstructs and verifies enough data to say regeneration is possible, then deletes the archive/alias, but creates no durable handoff. The retained local test directly confirms missing-route deletion. That is independent of the otherwise useful observer retry journal. Automatic recovery can be lost after the source cursor has moved on, while known-transaction or other-validator recovery may remain possible.

Delta and binding. All affected node paths are unchanged from the tested v3.1.0 source. No caller change creates a durable replacement for these branches.

Evidence. INHERITED_EXECUTED_NEGATIVE: `evidence/protocol/retained-evidence-checks.json#protocol_inherited` — Local missing-route durable-vote deletion test and raw PASS log reviewed. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Set-rotation deletion ordering and age-pruning regeneration check re-inspected.

Current source. xgr-node/interchain/runtime/iln_checkpoint.go:376-407; xgr-node/interchain/runtime/iln_storage.go:78-120.

Limits. The retained test demonstrates missing-route deletion; the rotated-set temporary-error and age-pruning branches are source proofs. No destructive production restart, rotation or exhaustion experiment occurred. The condition concerns lost automatic recovery work, not authenticated principal destruction.

Minimal action. Retain the original locator/evidence until a successor is durably persisted or delivery is authenticated as terminal. Use an atomic handoff for rotation and cleanup, then test failure after discovery, after rotation, during successor persistence and across restart.

Confidence. High.

Historical occurrence mapping. 2026-10-25/N-03.

F-21 - Successful incomplete discovery responses can advance durable cursors

Medium / P1 / OPEN · OFFEN.

Original cause. A successful single-provider log query is treated as a complete discovery window. A well-formed response that omits real events can therefore advance durable operation or route-discovery cursors without creating retry records for the omitted entries.

Current assessment. The multi-Gateway scanner validates returned entries, sorts/deduplicates them and retries transport errors, but returns the first successful response, including an empty one. The observer advances cursors after iterating only the returned operations. The retained injected-window test confirms advancement with no sign attempts and no retry entry for an empty successful window. RouteAdded discovery has the corresponding completeness boundary. Later signing still requires complete matching evidence from two counted operators, so omission affects discovery availability rather than forged message authorization.

Delta and binding. No node changes. Current source and retained v3.1.0 negative test refer to the same commit. UI recovery/observer work cannot recover an entirely unknown omitted message unless another discovery path supplies its identity.

Evidence. INHERITED_EXECUTED_NEGATIVE: `evidence/protocol/retained-evidence-checks.json#protocol_inherited` — Actual observer invoked with a successful empty injected window; durable cursor advancement confirmed. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Single-provider success path and both cursor consumers unchanged.

Current source. xgr-node/interchain/evm/iln_multi_gateway_scan.go:42-100; xgr-node/interchain/evm/iln_multi_gateway_scan.go:103-138; xgr-node/interchain/runtime/iln_observer_worker.go:110-159; xgr-node/interchain/evm/iln_discovery.go:39-63; xgr-node/interchain/runtime/iln_discovery.go:285-321.

Limits. An empty response cannot be declared false from its syntax. The test proves the completeness trust boundary, not actual provider censorship or a missed production transfer. The native XGR scanner uses local committed chain data and is a separate path.

Minimal action. Add bounded overlap/reconciliation or independent-provider completeness checking to discovery. Preserve known-transaction recovery and alert on differing windows. Keep full two-witness source verification for every eventually discovered message.

Confidence. High.

Historical occurrence mapping. 2026-10-25/N-04.

F-22 - Admin deployment evidence uses confirmation depth as finality

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: verifyDeploymentReceipt obtains latest head/confirmations plus canonical numeric receipt block, but never requests adopted native safe/finalized head.

Delta and regression assessment: Deployment verifier and all deployments unchanged. New live checks independently confirm current57 receipt/runtime identities; they do not repair future promotion logic.

Verification: Fresh historical-controls test F22 accepts a canonical depth-qualified receipt while mock safe head would be lower, and records no safe/finalized request. Existing deployment-ledger8/8 passes. Current57 canonical deployments independently checked.

Impact, existing mitigation and limits: Future contract promotion can occur before adopted source-native finality. No current deployed-bytecode substitution or reorganization observed.

Minimal remediation: Reuse shared chain-native finality policy and compare receipt height/hash before promotion; label provisional confirmation depth separately.

Exact frozen-source references: `services/admin/deployment-ledger.mjs:114-167`.

F-23 - Orphaned deployment locks require careful manual recovery

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: Exclusive intents.lock file has no persisted owner lease; a killed process can leave it while finally cleanup never executes.

Delta and regression assessment: Deployment-intents code unchanged. No product journal inspected or modified.

Verification: Fresh isolated-filesystem test opens intact prepared journal after an orphan lock, then attachHash fails EEXIST and preserves intent. Existing intent21/21 and journal2/2 pass.

Impact, existing mitigation and limits: Admin recovery may stop until stale ownership is established. Intact recorded transaction identity is preserved; no duplicate broadcast demonstrated.

Minimal remediation: Provide minimal explicit stale-owner verification/recovery retaining journal, nonce and signed-byte identity; never delete a lock solely because its wall-clock age is large.

Exact frozen-source references: `services/admin/deployment-intents.mjs:73-117`; `services/admin/deployment-intents.mjs:203-214`.

F-24 - Verified paid-fee backfill still omits required event identity

Original and unchanged cause.

Historical 24:L-06 and 25:L-06 map to F-24. `storeVerifiedOperation` at `services/indexer/transfer-index-worker.mjs:54-61` compares the verified record against `event.messageId` and `event.txHash`. `backfillPaidFeeTax` first authenticates the canonical source receipt and recovered quote nonce, then passes only block/log fields at lines 528-531. Both event identity fields are absent, so the shared guard rejects before insertion.

`Protected: quote/phase-b/source-equivalence.json` proves the entire worker blob is identical between the previous and new audit source freezes. This is not a recently introduced regression. The actual functions were nevertheless rerun in the new two-case historical harness. `verifiedTransfer` accepts the synthetic canonical receipt and recovers nonce 4242. `backfillPaidFeeTax` then returns `{verified:0,held:1}` with exactly BEGIN followed by ROLLBACK and no insert. The test initially lacked an eth_blockNumber fixture response; that harness error was corrected in the new audit fixture only and is recorded in `Protected: quote/phase-b/fixture-adjustments.md`. No application source was changed.

Low / OPEN; confidence High. Qualifying old fee records cannot finish this backfill. Ordinary new fee ingestion is separately tested and is not claimed broken. No production accounting rows were inspected and no principal or grant authorization is affected. Carry the already verified `row.message_id` and `row.source_tx_hash` into the event and add a successful-store regression, preserving the provenance guard.

F-25 - Dense event windows lack adaptive progress

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: Oversized bounded event windows fail before commit and are retried at the same cursor/window width instead of adaptively splitting.

Delta and regression assessment: Transfer-index source and scanning worker unchanged. New gas learner has a separate unknown-event cursor problem recorded as F35, not a duplicate of this event-count cap.

Verification: Fresh mock-RPC test of real readSourceWindow rejects151 events for one route on two sweeps and records identical0x1..0x96 ranges. Initial audit matcher mismatch corrected only in harness and retained. Existing transfer-index27/27 passes.

Impact, existing mitigation and limits: Legitimate dense history can block automatic indexing; known transaction-hash recovery and announcements remain possible. No actual dense production backlog claimed.

Minimal remediation: Adaptively split bounded block ranges, preserving complete canonical event processing; define a bounded dense-single-block path and retain cursor on uncertainty.

Exact frozen-source references: `services/indexer/transfer-index.mjs:235-257`; `services/indexer/transfer-index.mjs:290-353`; `services/indexer/transfer-index-worker.mjs:554-595`.

F-26 - Unknown route rows can starve background delivery refresh

Historical severity: Medium. **Current severity:** RESOLVED. **Disposition:** VERIFIED / RESOLVED. **Confidence:** High.

Original technical cause: Historical SQL applied LIMIT before filtering active source/route pairs, letting retired or cross-product rows crowd out valid delivery checks.

Delta and regression assessment: The corrected active-pair EXISTS filter and attempt rotation were present at the frozen baseline and remain byte-identical. New gas learner does not replace this worker.

Verification: Fresh PostgreSQL16.15 test with82 rows (81 retired/cross-pair blockers,1 active exact pair), LIMIT1, selects only active pair; controlled RPC failure rotates delivery_attempted_at while preserving delivered=false. Actual schema executed, no production DB.

Impact, existing mitigation and limits: Deployment/backlog inventory is distinct from source closure. Other observer completeness/size failures remain separately registered.

Minimal remediation: Retain exact-pair selection before LIMIT and outage scheduling regression. No product correction is needed for the original cause.

Exact frozen-source references: `services/indexer/transfer-index-worker.mjs:197-236`; `services/indexer/sql/002_transfer_operations.sql:25`.

F-27 - Published CLI version fields are empty despite valid embedded VCS data

RESOLVED / P2 / VERIFIED.

Original cause. The former release workflow passed linker targets for an obsolete module path, leaving four product CLI version fields empty despite valid embedded Go VCS metadata.

Current assessment. The current workflow derives the versioning package from go list -m and sets Version, Commit, Branch and BuildTime. It checks release version and commit in the binary output. The recovered v3.4.0 artifact record includes the verified checksum and CLI output with v3.4.0, branch XGR3.0, commit cbe6f8a and a build timestamp; embedded metadata resolves the release commit. The release differs from the frozen node only in three documentation files. Retain VERIFIED / RESOLVED.

Delta and binding. Already corrected and verified in the latest v3.1.0 report; no node delta. Fresh source checks confirm the release workflow and version module are unchanged, and public RPC version observations remain consistent with v3.4.0.

Evidence. INHERITED_RELEASE_IDENTITY: `evidence/protocol/retained-evidence-checks.json#protected_inputs_reviewed_hashes_only` — Retained release-artifact verification, product-version output and Go buildinfo hashes reviewed. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Corrected linker module path and version module match current frozen source. FRESH_READ_ONLY_PRODUCTION: `evidence/protocol/public-chain-evidence-summary.json (raw RPC records protected)` — Both XGR RPC hosts self-report v3.4.0.

Current source. xgr-node/.github/workflows/release.yml:93-130; xgr-node/versioning/versioning.go:1-18; xgr-node/command/version/version.go:1-50.

Limits. The published artifact was checked in the retained audit, not downloaded or executed again here. RPC Go1.23.11 and the published artifact Go1.23.12 are distinct build identities; this does not contradict source equivalence. Per-host installed disk hashes are not inferred.

Minimal action. Retain nonempty CLI field checks and embedded revision/checksum checks in release validation. Reconcile deployed host binary identities through ordinary operations when available; the original linker-path defect is closed.

Confidence. High.

Historical occurrence mapping. 2026-10-24/I-02, 2026-10-25/I-02.

F-28 - Compiler advisory applicability remains an assurance gap

Informational / P2 / OPEN.

Original cause. The historical review left a project-specific compiler-equivalence/applicability question open for the Solidity 0.8.24 optimized via-IR artifacts. The old historical register included an advisory identifier; this audit does not adopt that identifier or its alleged affected-version range as a newly verified official fact.

Current assessment. foundry.toml still declares Solidity 0.8.24, optimization with 200 runs and via_ir. The retained build record explains the actual compiler target as Cancun despite the configured Prague runtime target. Historical comparisons matched instruction bodies after documented immutable/metadata exclusions; fresh Phase A independently matched all 57 runtime bytecode hashes to the deployment manifests. Those identity checks are strong provenance evidence but do not establish compiler semantic equivalence. Retain an Informational assurance task, with no demonstrated project miscompilation or principal-loss path.

Delta and binding. Solidity sources, compiler/dependency declarations and deployed runtime identities are unchanged. No advisory applicability lookup, compiler differential or fresh compile was performed, so no current advisory claim is made.

Evidence. INHERITED_BUILD_EVIDENCE: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/build-environment.json` — solc 0.8.24+e11b9ed9, viaIR/optimizer and actual Cancun compiler-target record. INHERITED_BUILD_EVIDENCE: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/contracts/runtime-comparison.json` — 57 normalized runtime comparisons with explicit immutable/metadata limitations. FRESH_READ_ONLY_PRODUCTION: `evidence/protocol/deployment-identity-checks.json` — 57 exact runtime hashes matched their receipt/manifests. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Build settings and relevant source unchanged.

Current source. xgr-interchain/foundry.toml:1-17; xgr-interchain/vendor/package.json:1-20.

Limits. An unverified historical advisory assertion cannot establish current exposure. Runtime identity is not a semantic compiler proof, and an arbitrary newer-compiler build alone would not settle a specific trigger. No specific official applicability claim is needed for this retained Informational gap.

Minimal action. First verify the exact official advisory and trigger applicability if this task is pursued as a concrete exposure. Then qualify the precise build/settings with a targeted corrected compiler or suitable equivalence method. Do not infer a need to redeploy existing contracts solely from the historical unexcluded question.

Confidence. High that the assurance work remains unperformed; no confidence claim about an unverified specific compiler defect.

Historical occurrence mapping. 2026-10-24/I-03, 2026-10-25/I-03.

F-29 - Membership and governance submission RPC remains unbounded

Medium / P1 / OPEN · OFFEN.

Original cause. Read-side witness RPC gained deadlines and worker-scope cancellation, but external membership and governance submissions construct a separate legacy transaction relayer. Its receipt timeout controls the interval between polls, not a bound on each preflight/send/receipt network call.

Current assessment. Both current external submission paths select a verified URL and then construct NewTxRelayer with only address and polling interval. They do not pass the bounded read client or shutdown context. The relayer performs nonce, chain ID, preflight, send and receipt RPC through that client. Worker.Close cancels scoped reads and waits for worker goroutines; the governance executor and

membership submission caller can remain inside the separate transport. IBFT shutdown calls this worker close. A hanging provider can therefore retain work and impede orderly shutdown. The bounded witness client is a partial mitigation, not closure of the original lifecycle condition.

Delta and binding. No change to node callers, transaction relayer or dependency declarations. The historical dependency trace of the exact pinned ethgo/fasthttp versions is inherited; no extra repository or dependency installation was accessed.

Evidence. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Active submission/close call graph and unchanged dependency manifests checked. INHERITED_DEPENDENCY_TRACE: `../2026-10-27-xita-direct-bls-final-v3.0.0/evidence-public.zip!/node/m04-transport-static.json` — Exact pinned transport-source fingerprints and default unbounded client behavior; source outside the allowed repos was not newly retrieved.

Current source. xgr-node/interchain/evm/client.go:400-448; xgr-node/interchain/evm/iln_governance_submit.go:130-153; xgr-node/txrelayer/txrelayer.go:61-80; xgr-node/txrelayer/txrelayer.go:95-135; xgr-node/txrelayer/txrelayer.go:256-275; xgr-node/interchain/runtime/worker.go:325-348; xgr-node/interchain/runtime/governance_execute.go:24-47; xgr-node/interchain/runtime/governance_execute.go:75-83; xgr-node/consensus/ibft/ibft.go:695-705.

Limits. No live transaction or intentionally hanging production call was executed. The relevant prerequisite is an eligible membership action or explicitly authorized governance submission to an unresponsive external transport. Existing read-cancellation tests do not establish the behavior of the separate send client, and no running-consensus halt is claimed.

Minimal action. Carry bounded context-aware transport through preflight, submission and receipt waits, and test complete Worker.Close termination. Preserve original transaction identity and nonce when a send outcome is uncertain; an outer sleep timeout or blind replacement broadcast is insufficient.

Confidence. High.

Historical occurrence mapping. 2026-10-24/M-04, 2026-10-25/M-04.

F-30 - Reconciliation refresh suppresses delayed-grant monitoring

VERIFIED / RESOLVED; current severity None; confidence High.

Original technical cause. Retry scheduling refreshed updated_at while both delayed-grant and paid-commitment diagnostics used updated_at as the fifteen-minute age predicate, hiding old unresolved payouts after every retry.

Relevant implemented changes. 081e1d57dd1e69f82dd29527596168f66653383c changes both monitor age predicates to immutable created_at.

Independent verification and provenance. Fresh real PostgreSQL regression retains a delayed alert after updating retry heartbeat to NOW. Fresh query source/unit evidence confirms both age predicates use creation time. Hash-verified protected v3.1 traces preserve original two-alert-to-zero-alert reproduction after actual reconciler and wrong-recipient error paths.

Current assessment and limits. The original age suppression is removed. New read-only table access omission belongs to re-opened F06; actual scheduled invocation/alarm delivery remains an operational assurance boundary. A no-aged-alerts result never means all financial obligations are settled.

Narrow next action. Retain immutable age predicates, restore the reader privilege dependency under F06 and verify installed alert delivery with existing synthetic/aggregate evidence. Do not conflate heartbeat age with debt age.

Frozen source references: `services/managed-relay/sponsor-obligation-audit.mjs:4-18`, `services/managed-relay/sponsor-obligation-audit.mjs:24-60`, `services/managed-relay/gas-sponsor.mjs:572-581`, `services/managed-relay/sponsor-obligation-audit.pg.test.mjs:150-156`.

Evidence references: `../../root/test-logs/services__managed-relay__sponsor-obligation-audit.pg.test.mjs.log`, `../existing-monitor-unit-direct.log`, `protected-v3.1/services/independent/independent-services-pg.tap`, `protected-v3.1/services/records/phaseB-services.json`.

F-31 - A failed destination receipt can retain transaction-submitted wording

Historical severity: Low. **Current severity:** Low. **Disposition:** OPEN. **Confidence:** High.

Original technical cause: The retained first-delivery-pending stage outranks a failure notice after destination receipt failure; the UI renders submitted/do-not-resubmit wording despite failed result.

Delta and regression assessment: transfer-status-flow.js only adds spendable status. app.js only extends sponsor status allowlist. Destination-failure stage precedence remains unchanged.

Verification: Fresh real renderer reproduction confirms submitted wording and absence of failure notice with failed destination result; deriveTransferFlow still delivered=false. Matches hash-verified protected v3.1 original renderer proof.

Impact, existing mitigation and limits: Misleading recovery instruction can delay correct destination retry. It does not confirm principal payout or authorize another source lock.

Minimal remediation: Record and prioritize explicit destination-receipt failure state over stale pending stage; keep the existing source evidence and only offer destination retry.

Exact frozen-source references: `apps/web/app.js:766-779`; `apps/web/transfer-status-flow.js:195-209`; `apps/web/transfer-status-flow.js:249-282`.

F-32 - Expired unverified route hints leave permanent per-message request storage

Medium / P1 / OPEN · **OFFEN**.

Original cause. An unauthenticated unknown-route quorum request allocates both a discovery hint and a per-message request directory before canonical route admission. Hint expiry/rejection removes only the hint, while background request cleanup traverses known routes only.

Current assessment. Admission has a 128-hint bound and a per-route live-request bound, with lazy expiry when that same route is revisited. These do not bound accumulated abandoned unknown-route directories across hint churn. The status getter reports EXPIRED_RETRY without removing the request. The recovered v3.1.0 tests invoke the actual endpoint with local temporary heartbeat/storage, then invoke actual expiry and request processing, confirming that the hint disappears while the request survives outside traversal. No signature or source evidence is trusted from the hint. The condition is persistent unauthenticated disk/inode pressure, assessed Medium availability risk.

Delta and binding. This was new in v3.1.0 and is unchanged at the current identical node HEAD. No fresh public RPC flood or storage-exhaustion run was performed. Fresh source search confirms no global quorum-requests cleanup was added.

Evidence. INHERITED_EXECUTED_NEGATIVE: `evidence/protocol/retained-evidence-checks.json#protocol_inherited` — Two exact-source local tests separately confirm prevalidation request storage and survival after hint expiry; raw fixtures/logs inspected. SOURCE_PROOF: `evidence/protocol/phase-b-source-identity.json` — Producer, lease rejection, status read and cleanup traversal rechecked at current HEAD.

Current source. xgr-node/jsonrpc/xgr_iln_quorum.go:36-124; xgr-node/jsonrpc/xgr_iln_quorum.go:180-188; xgr-node/interchain/runtime/iln_quorum_request.go:118-140; xgr-node/interchain/runtime/iln_discovery.go:209-263; xgr-node/interchain/runtime/iln_storage.go:137-166.

Limits. The local negative fixtures establish the lifecycle leak, not production disk exhaustion or a quantified attack cost. The 128-entry limits constrain each live hint window/route, so the finding does not assert unbounded instantaneous single-call allocation. Detailed fixture payloads remain protected.

Minimal action. Apply a global bounded admission/retention policy to unverified request storage and reap expired unknown-route directories, or allocate message jobs only after canonical route admission. Preserve verified votes and paid recovery obligations; test hint rejection, expiry, churn and restart cleanup.

Confidence. High.

Complete 43-occurrence historical matrix

The table below displays current decisions while retaining date-qualified original identities and severities. The CSV/JSON preserve all 16 prior cells verbatim, adding explicit v3_2_* fields. Thirty occurrences map to 18 current F-IDs; thirteen are legacy-only occurrences. Fourteen duplicate-of references remain preserved. None of those repeats is added to current severity totals.

Historical occurrence	Original	Current	Disposition	Current ID
2026-10-24/H-01	High	Medium	OPEN	F-05
2026-10-24/M-01	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-24/M-02	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-24/M-03	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-24/M-04	Medium	Medium	OPEN	F-29
2026-10-24/M-05	Medium	Medium	OPEN	F-03
2026-10-24/M-06	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-24/L-01	Low	Low	OPEN	F-13
2026-10-24/L-02	Low	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-24/L-03	Low	Low	OPEN	F-10
2026-10-24/L-04	Low	Low	OPEN	F-22
2026-10-24/L-05	Low	Low	OPEN	F-23
2026-10-24/L-06	Low	Low	OPEN	F-24
2026-10-24/L-07	Low	Low	OPEN	F-25
2026-10-24/I-01	Informational	Low	OPEN	F-14

Historical occurrence	Original	Current	Disposition	Current ID
2026-10-24/I-02	Informational	RESOLVED	VERIFIED / RESOLVED	F-27
2026-10-24/I-03	Informational	Informational	OPEN	F-28
2026-10-25/H-01	High	Medium	OPEN	F-05
2026-10-25/M-04	Medium	Medium	OPEN	F-29
2026-10-25/M-05	Medium	Medium	OPEN	F-03
2026-10-25/M-06	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/L-01	Low	Low	OPEN	F-13
2026-10-25/L-02	Low	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/L-03	Low	Low	OPEN	F-10
2026-10-25/L-04	Low	Low	OPEN	F-22
2026-10-25/L-05	Low	Low	OPEN	F-23
2026-10-25/L-06	Low	Low	OPEN	F-24
2026-10-25/L-07	Low	Low	OPEN	F-25
2026-10-25/I-01	Informational	Low	OPEN	F-14
2026-10-25/I-02	Informational	RESOLVED	VERIFIED / RESOLVED	F-27
2026-10-25/I-03	Informational	Informational	OPEN	F-28
2026-10-25/N-01	High	Medium	OPEN	F-04
2026-10-25/N-02	High	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/N-03	Medium	Medium	OPEN	F-20
2026-10-25/N-04	Medium	Medium	OPEN	F-21
2026-10-25/N-05	High	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/N-06	Medium	Medium	PARTIALLY_MITIGATED	F-17
2026-10-25/N-07	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/N-08	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause
2026-10-25/N-09	Medium	Medium	OPEN	F-09
2026-10-25/N-10	Low	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause

Historical occurrence	Original	Current	Disposition	Current ID
2026-10-25/N-11	Medium	RESOLVED	VERIFIED / RESOLVED	F-26
2026-10-25/N-12	Medium	RESOLVED	VERIFIED / RESOLVED	Legacy-only cause

Legacy-only verified controls

The thirteen occurrences without an active F-ID were also inspected. Source-finality gating, code-bearing-wallet gas estimation, complete two-hop obligation recognition, permanent payout finality, complete aggregate commitment locks, source-hint persistence and microfee candidate filtering retain their verified controls. Corresponding fresh stage, source-hint, wallet and PostgreSQL tests are identified in the execution ledger, and original SQL/fault proofs are explicitly inherited.

The historical M-03 synchronization gate is now VERIFIED / SCHLIESSBAR by a complete current source proof covering observer, on-demand, public, peer and retry entry points to the sole Direct-message signing sink; both synchronization guards dominate signing and nil state fails closed. No fresh Go runtime test is implied. M-06 route-hint queue fairness and N-02 multi-Dispatch event matching retain closure through unchanged current source and actually executed inherited tests. The remaining absence of a dedicated M-03 behavioral regression is useful future coverage, not a source counterexample.

The historical matrix's 43-occurrence disposition totals are 26 OPEN, one PARTIALLY_MITIGATED and 16 VERIFIED / RESOLVED. Those occurrence counts are intentionally different from the 35-entry current register. `prior-findings-matrix.md` and the matrix validation artifact explain the mapping and identity checks in machine-readable detail.

7. Sponsorship security and financial obligations

The changed service now prepares and verifies the sponsor transaction before committing its nonce reservation, journals exact signed bytes atomically, recovers prepared work, distinguishes provisional inclusion from safe final confirmation, retains externally overtaken liabilities, checks two external expiry witnesses, bounds persistent same-wallet admission, and ages delayed work from immutable creation time. These are material improvements. Each is assessed at its own boundary: exact-byte recovery resolves F-07; two-witness canonical expiry resolves F-16; immutable monitoring age resolves F-30. Their closure does not conceal F-33 or substitute a green monitor for complete lifecycle settlement.

The financial model distinguishes an unpaid signed promise, a verified paid TX1, all promised destination/hub stages, a reserved nonce with immutable transaction identity, submitted/uncertain work, provisional spendability and safe confirmation. Expiration of a quote is not proof that it was unused; a failed or absent RPC response cannot release a promise. A completed destination does not erase an earlier paid obligation. Native user principal remains outside the gas gift amount. The following complete invariant assessment applies under the stated source-evidence, key, database and finality assumptions.

Audit: `XITA-DBLS-2026-10-29-v3.2.0`.

Frozen source: `xgr-network/xgr-interchain@5cfc095d0f02271427832ee6bbb268322f38ae2d`.

Interpretation.

The source column assesses the ten specific invariants in the audit brief using the frozen source and already executed verification. **PASS** means the scoped control is implemented and supported by the cited source/test evidence; it is not a guarantee beyond the stated assumptions. **PARTIAL** means only part of the relevant control or evidence is established. **FAIL** means a concrete counterexample was demonstrated. No additional tests were run to create this matrix.

The production column measures installation/evidence sufficiency separately. The new read-only public health response reports sponsoring enabled and available, but this workstream has not inspected the installed worker revision, effective PostgreSQL privileges or private grant journal on every host. Consequently production entries are **PARTIAL**, not assertions of observed violations or an outage. A source FAIL does not mean the defect has been seen exploited in production. Conversely a green public health response does not establish all invariants.

The source assessment assumes authentic source and destination evidence under the adopted chain-native finality policy, protected sponsor signing keys, database integrity within the documented role boundary, and the documented contract/route bindings. External RPC correlation remains a separately assessed trust boundary. No runtime state or risk acceptance is inferred from a merge.

Ten requested invariants.

No.	Required invariant	Frozen-source result	Production evidence	Scope and principal evidence
1	No additional user transaction or wallet signature for sponsorship	**PASS**	**PARTIAL**	The sponsor signs its own native-gas transaction; the user's original paid TX1 is the authorization evidence. Prepared recovery uses original sponsor-signed bytes. `gas-sponsor.mjs:125-141,204-299,460-489`. Existing stage/binding tests and sealed restart tests.
2	No sponsor payout before a verified, paid TX1	**PASS**	**PARTIAL**	Initial admission reconstructs and verifies the payer-bound source receipt and native finality, then matches immutable quote nonce, fee, route, amount and recipients. `gas-sponsor.mjs:63-80,125-141,216-232`; `wallet-transfers.js:298-411`. Fresh finality negatives and quote-binding tests; original entrypoint fault tests are inherited.
3	All required sponsor obligations are considered immediately after TX1	**PASS**	**PARTIAL**	All positive first-delivery, hub-onward and final-delivery commitments are written atomically with the quote and selected from the original paid parent without a child transaction prerequisite. `tax-evidence.mjs:114-196`; `gas-sponsor.mjs:29-42,771-790`. Fresh stage/atomicity tests, unchanged candidate-query hash, inherited real-SQL three-stage proof.
4	No new gas payout after completed destination delivery	**FAIL**	**PARTIAL**	An initial delivery check exists, but a timed-out inspector can resume and initiate its original prepared payout after destination completion. `gas-sponsor.mjs:423-431,437-458,473-489,539-540`. Newly demonstrated during sealed Phase A; **F-33**.
5	No duplicate payout for the same grant	**PASS**	**PARTIAL**	Grant identity and chain/sponsor/nonce are unique; restart can only rebroadcast exact original signed bytes/hash. `004_sponsor_grants.sql:4-18`; `013_sponsor_prepared_tx.sql:3-8`; `gas-sponsor.mjs:330-370,460-495`. Fresh real-PostgreSQL concurrent nonce/rollback tests and exact-byte recovery test.
6	No unjustified deletion or release of existing obligations	**PASS**, for retention/release authorization	**PARTIAL**	The reviewed worker does not delete promises or clear nonce reservations. Expired-unused release requires complete native/witness evidence; externally overtaken obligations are recorded durably. `gas-sponsor.mjs:628-754`; `tax-evidence.mjs:147-162`; migrations 012-014. Fresh witness-negative and durable-ledger checks. Fulfillment/settlement remains partial under **F-19**; retention alone is not settlement.

No.	Required invariant	Frozen-source result	Production evidence	Scope and principal evidence
7	No uncontrolled reuse of a reserved nonce	**PASS**	**PARTIAL**	PostgreSQL serializes reserve admission and enforces nonce uniqueness; consumed nonces are held for review and never replaced automatically. `gas-sponsor.mjs:330-370,473-489`; `004_sponsor_grants.sql:17`. Fresh concurrent distinct-key/same-nonce test and consumed-nonce test.
8	No re-signing with a changed amount or recipient while transaction status is uncertain	**PASS**	**PARTIAL**	Recovery verifies the durable signed hash and sender/recipient/value/nonce/chain, then submits identical bytes. It does not call the signer. `gas-sponsor.mjs:460-489`. Fresh exact-byte recovery and identity-mismatch tests.
9	No silent financial release on incomplete RPC evidence	**PASS**, for financial release /confirmation	**PARTIAL**	Missing, conflicting or lagging expiry evidence causes retention; permanent confirmation requires canonical native-safe evidence. Resolution writes occur only after completed read-only proof. `gas-sponsor.mjs:182-201,628-725`; `tax-evidence.mjs:151-161`. Fresh witness and safe-finality tests. Provisional readiness has a separate Low projection defect, **F-34**, and must not be treated as settlement.
10	No sponsorship of the user's native principal	**PASS**	**PARTIAL**	Quote construction subtracts second-hop native principal before deriving the onward protocol fee; the allocator covers buffered gas and protocol fee only. `quote-service.mjs:111-124,149-167`; `wallet-aware-sponsorship.mjs:26-40`; `gas-sponsor.mjs:44-61,227-232`. Fresh wallet-aware principal-exclusion and grant-binding tests.

Paths without a directory prefix in this table refer to `services/managed-relay/`, except numbered SQL files under `services/indexer/sql/` and `wallet-transfers.js` under `apps/web/`. All references use the frozen commit above.

Necessary qualifications by control boundary.

Original source authorization and user signatures.

The sponsor does not treat an arbitrary API request, positive fee alone, or a UI claim as payout authority. Its initial candidate independently rehydrates the original transaction, verifies successful receipt identity, source native finality and destination status, and matches the immutable payer-bound commitment. The source receipt/finality helpers remain hash-identical to the previous baseline. New recovery trusts a valid original prepared transaction only after checking its signature-derived fields against the durable row. This is consistent with invariants 1, 2 and 8, but relies on the integrity of the original source-verification and storage boundaries.

A source PASS does not claim that an individual real payment was observed at each production step. The report intentionally avoids new Mainnet test payments. Existing immutable transaction/receipt evidence and installed-source/role observations can provide production corroboration without adding another user signature.

All stages counted versus all stages fulfilled.

Invariant 3 concerns complete obligation recognition after the original TX1. The current candidate query and stage function do not wait for TX2, TX3 or a second-hop child message before recognizing the final-chain grant. Those exact control blocks are unchanged from the previously verified fix; current stage and atomic-commitment tests also passed. Database errors roll the whole quote transaction back rather than issuing a partially stored promise.

This PASS does not mean the worker always fulfills every obligation promptly. F-08 concerns delayed independent work, and F-19 concerns externally advanced or globally disabled servicing. The new overtaken ledger improves durable visibility while leaving final settlement unresolved. The distinction is necessary to avoid reopening the old circular-stage defect N-05 merely because a different lifecycle failure remains.

Unique identity does not make a late send authorized.

The reserved nonce and exact-byte journal prevent creation of a second distinct payment for the same grant. The real PostgreSQL tests showed only one competing reservation survives, and a failure while inserting prepared bytes rolls the grant reservation back atomically. Same-byte retransmission has the same transaction identity; multiple legitimate stages for one user are not duplicates of one grant.

F-33 violates a different condition. A deadline has expired and the caller has returned a held result, yet the unfinished callback can later start the originally authorized native-gas transaction using an old destination eligibility observation. Invariants 5, 7 and 8 can hold while invariant 4 fails. The repair must therefore fence side effects, not weaken uniqueness or invent a replacement payment. The exact amount and recipient remain bounded, so this finding is Medium rather than evidence of arbitrary principal theft.

Retention, safe expiry and unresolved liabilities.

The persistent per-wallet quote admission window is not the treasury-liability release window. Expiration can make a wallet eligible to request a new quote, while the earlier financial promise remains in aggregate liability accounting until a separately verified unused resolution or safe matched payout applies. The current expiry function requires a matching finalized block/nonce view from the configured external witnesses and canonical rereads. Missing or inconsistent evidence does not create an expired-unused resolution.

The worker and diagnostic do not delete the append-only overtaken ledger or label it paid. This supports invariant 6's literal no-unjustified-deletion/release requirement. It does not close F-19: a retained debt can still lack a defined outcome, and the global stop currently suppresses servicing rather than distinguishing new admissions from existing obligations. A durable record is not financial settlement or operator acceptance.

Provisional gas usability versus permanent confirmation.

Invariant 9's PASS applies to permanent financial release and safe confirmation. It must not be read as approval of all readiness projections. F-34 shows that a provisional inclusion marker can remain after its evidence disappears, or fail to become publicly usable during crash recovery because the status/hash transition is missing. The confirmed-state finality check remains separate and unchanged. The frontend's current native-balance preflight limits the demonstrated consequence to availability and presentation; it does not convert a stale marker into permission to spend nonexistent gas.

Native principal remains the user's contribution.

The actual quote builder determines second-hop principal from token mode, subtracts it from the bridge-native quote and passes only the resulting protocol fee alongside gas estimates to the wallet-aware allocator. The allocator consumes each chain's existing wallet balance once and adds gas/fee shortfalls. The worker later pays exactly that authenticated immutable gas promise. The separate legacy `sponsorGrantNeed` helper also refuses to subsidize insufficient native principal, but the PASS is based on the current quote-builder/allocator path, not that helper alone.

Evidence already collected.

- Sealed sponsor unit runs: 20 worker, six obligation-monitor and seven public-status tests; these include stage eligibility, binding, nonce, finality, witness and monitor semantics.
- Sealed independent recovery tests: the concrete F-33 late-side-effect observation and both F-34 state-projection observations. These are defect demonstrations, not invariant passes. Executable harnesses and raw security traces remain in the protected evidence package.
- Sealed real-PostgreSQL adversarial scenarios: documented status-reader failure, competing nonce reservation and atomic rollback on prepared-journal failure. The role omission is consolidated in F-06.
- Root's fresh real-schema suite: 12 reported test events, including the containing test, for atomic journaling, immutable-age monitoring, durable overtaken obligations and disabled-state retention.
- Root's fresh four native-finality tests, four wallet-aware funding tests and relevant frontend tests.
- Hash comparisons for four unchanged files and six control blocks in `control-hash-comparison.json`; inherited original historical entrypoint/candidate SQL evidence is explicitly separated from new execution.
- Fresh read-only health evidence in `root/public-sponsor-health.json`: HTTP 200, `paidQuoteReady=true`, sponsorship enabled and available at `2026-10-29T08:55:03.799647Z`.

The ten literal source invariants therefore have nine scoped PASS results and one demonstrated FAIL. This does not authorize regular unattended sponsorship: F-33 directly violates a requested financial-control invariant, and F-06/F-08/F-17/F-19 describe additional installation, admission, availability and paid-lifecycle risks that are not exhausted by these ten predicates. No production failure or missing-host NO-GO is invented from incomplete evidence.

Database and monitoring boundaries

Real PostgreSQL tests exercise canonical grants as well as superuser-created schema. The original missing operations/resolutions read was fixed, but newly introduced intents and overtaken-table reads lack matching restricted-role grants and readiness assertions (F-06). The actual denied admission rolls back; no partially issued quote is inferred. The monitor throws visibly rather than silently reporting a clean zero. Granting the exact missing SELECT in a disposable fixture allowed separate locking/accounting controls to be tested without modifying product code.

Advisory locks and uniqueness serialize aggregate chain capacity, grant identity and sponsor nonces. Failure to insert the prepared journal rolls back its reservation. Two distinct wallets racing insufficient aggregate capacity admit only one, and failed second-chain funding rolls back the entire multi-stage quote. Expired but unproven-unused promises continue counting against capacity. Conservative in-flight double counting (F-18) can reject too much capacity but does not establish an insolvency undercount.

The overtaken ledger makes otherwise lost obligations durable and monitorable. It does not, by itself, decide an authorized outcome. A safe policy must preserve liabilities and transaction identities, distinguish a new admission stop from existing servicing, and record controlled settlement rather than automatic late payment. F-19 remains PARTIALLY_MITIGATED. The audit makes no production ledger adjustment and does not treat debt deletion or nonce recycling as acceptable remediation.

8. Protocol, consensus, principal and recovery assessment

Direct-BLS authentication and contract principal

The inspected encoder/decoder and Solidity authorization structures bind per-message data to the intended route, source/destination chains and contracts, source block number, message hash and fee fields; the message hash covers the payload. The Direct-BLS signature does not directly include the source transaction hash or canonical block hash. Signers independently verify those through source receipt evidence, and external witnesses compare them as part of the complete operation. The destination ISM authenticates the current set, quorum, domain, route and message authorization. Mailbox processing separately enforces replay state. Source signers reconstruct the paid operation and destination verifier/registry configuration before signing. Durable signing/recovery paths preserve exact identity. Current membership and proof-of-possession checks remain the explicit trust boundary; membership authorization's registry-domain limitation is retained as F-11 rather than overlooked.

The one-hop route locks/burns the source representation and releases/mints only under authenticated destination delivery. XGRChain remains the hub for two-hop routes. A normal one-hop flow has source TX1 and destination delivery TX2. A normal two-hop flow has source TX1, hub delivery TX2, onward source TX3 and final delivery TX4. These are separately validated wallet and contract actions; the original paid quote recognizes every promised gas stage without waiting on a future child transaction. Permissionless routing does not imply enrollment in the UI catalog. That distinction is relevant to optional gas sampling (F-35), while consensus route discovery uses its registry evidence independently.

Native principal accounting and guarded-router deferred claims remain contract-backed even when the recipient cannot immediately accept native value. A completed Mailbox process is therefore not sufficient evidence of recipient payout; F-09's current UI claim is reproduced and remains Medium. The minimum committee size is an operating control (F-12), and authorized ownership transfer can collapse service/admin separation (F-10). These are distinct from an unauthorized ownership takeover.

The relevant source boundaries are cited in F-01/F-02/F-05/F-09/F-10/F-11/F-12 and `evidence/coverage/protocol.json`, including XITADirectProtocol, XITADirectBLSISM, ValidatorRegistryV3, BLSVerifier, ExecutionGateway, GuardedNativeWarpRouter and TokenFactoryV315. Contract bytes and dependency identities are unchanged. Old contract tests apply only where exact identity was established; native changes instead use the corrected candidate's retained tests.

Native consensus and external-chain finality

The current node is identical to the corrected baseline. Fork-gated StateTx rejection, exact non-executing marker validation, deterministic base-fee validation, transaction-local original-storage snapshots and checked refund propagation remain in place. The retained independent native logs, deliberately failing old baseline and local four-validator fork-crossing log were actually parsed and hash-verified. Source-to-v3.4 release equivalence and both current endpoint version/fork observations are corroborative. No per-host installation proof or new network fault injection is claimed.

XGR source evidence uses synchronized local committed IBFT state. Base/Arbitrum use complete, endpoint-pinned source/route/receipt/fee observations and adopted safe-finality heads with numeric canonical block-hash equality. Different operator labels must agree, but labels do not prove independent upstream infrastructure. A first matching pair may succeed despite an earlier disagreeing provider. That retained negative case is verified and F-05 remains Medium with its exact threat prerequisites. Safe L2 state is not represented as unconditional Ethereum settlement.

Expiry of unused sponsor quotes has a narrower, newly corrected two-witness requirement and canonical reread. Missing, conflicting, stale or reorged observations fail closed, which supports F-16

source closure. It does not eliminate the broader correlated-provider trust boundary or prove every production endpoint's independence. The report keeps those causes separate.

Recovery and bounded availability

Durable checkpoints/retries preserve many pending identities and allow independent signing recovery without a centrally trusted XITA relayer. Remaining availability failures are concrete but scoped: unbounded aggregate admission (F-03); fixed retry ordering and source-group journal errors (F-04); deletion before durable replacement (F-20); successful incomplete discovery advancing a cursor (F-21); unbounded governance/submission RPC (F-29); and expired-hint request storage persisting indefinitely (F-32). Inherited actual negative logs on the unchanged candidate and current source proofs support these findings. No production consensus halt was demonstrated.

The transfer index has separate concerns: canonical delivery-state reversal remains correct, active-route fairness is now freshly verified (F-26), while dense event windows (F-25) and old paid-fee backfill (F-24) still need small corrections. Admin deployment-finality promotion (F-22) and stale-owner recovery (F-23) are separate operational controls. Current live deployment identities do not repair future promotion logic, and an intact deployment journal does not eliminate an orphan lock. The conditional recovery decision therefore requires explicit known-identity recovery and backlog monitoring, excluding unsafe sponsor replay.

9. Tests, negative controls and evidence

Method / track	Fresh result	Meaning and limitation
Root Phase A	33 files; 264 reported events; 263 pass, 1 fail, 0 skipped	Includes real PostgreSQL and exact transfer/finality/wallet paths. The disclosed failure is a pre-existing contradictory RPC expectation.
Root Phase B	78 existing tests; 4 targeted historical controls; 1 PostgreSQL scenario	Four negative controls reproduce existing defects; the exact-pair PostgreSQL scenario supports F-26 closure. Initial harness matcher failure retained.
Sponsor Phase A / B	39 fresh leaf cases in A; one additional arithmetic case in B	Existing units, three recovery/transition cases and three real database cases; detailed reruns overlap and are not additional unique cases.
Quote / gas learner	50 existing tests; 4 observer cases; 7 nested PostgreSQL cases; 2 Phase B cases	Durable per-wallet/aggregate locks, rollback and real privilege denial tested; custom negative assertions deliberately establish defects.
Protocol Phase B	One fresh UI projection with five assertions	Actual current modules reproduce native-claim completion wording; no Go or Foundry rerun claimed.
Read-only deployment / release	57 runtime hashes, 57 canonical successful receipts, 60 manifest references	Current endpoint observations and release/source matching; no new production transaction or per-host binary attestation.
Inherited executions	Actual native, contract and protocol logs recovered and verified	Exact tested-source equality or explicit older-source boundary recorded. Expected historical baseline failure is not a current candidate failure.

All 64 separately recorded fresh execution invocations have exact commands, source identities, UTC timing, runtime/environment, expected and observed behavior, output hashes and access locations in `evidence/fresh-test-executions.json`. One additional current-module protocol scenario and its command/result metadata are in `evidence/protocol/`. This is an invocation ledger, not a claim of 64 unique suites or a deduplicated total assertion count. Detailed existing-product test logs are public; custom negative fixtures and raw sensitive traces are preserved in the protected package.

The principal new negative controls include delayed recovery completing after its caller, nonce-consumed uncertainty, prepared-journal transaction rollback, competing nonce reservation, canonical versus noncanonical receipts, receipt disappearance, unequal expiry witnesses, one-provider failure, safe-head lag, a canonical block changing on reread, same-payer concurrent admission, independent-payer aggregate capacity, multi-chain rollback, exact restricted-role denial, unknown optional-sample records, exact active route pairs and failed destination UI states. Each passing negative assertion is interpreted according to the invariant it tested. A test proving an adverse outcome never becomes a closure claim merely because its runner exits zero.

The root's unchanged rpc-read suite reports one failure: an old negative test rejects numeric block-pinned eth_call while a later test and the actual permitted read path accept it. Both files match the baseline blobs. Nine other cases pass. F-14 records the contradiction and omission from explicit CI discovery. New gas-profile/observer suites and an old expiry mock's no-longer-matching query shape also expose coverage limits. No product test was edited to manufacture a green audit.

Harness-only failures are retained separately. The initial historical-control matcher omitted the expected word excessive; the initial backfill fixture lacked an eth_blockNumber response. Corrections were confined to the disposable audit tests. A localhost sandbox denial preceded an approved isolated PostgreSQL rerun. Early node --test output sometimes summarized files rather than their subtests;

detailed direct/isolation-none outputs supersede only the reporting granularity, not the underlying source. Two earlier quote attempts survive as note-only records, with unavailable exact command vectors, UTC intervals and raw-log hashes explicitly null in evidence/unlogged-attempts.json. The successful documented reruns supply the finding evidence. These events are not product security failures and are not silently presented as fully logged executions.

The recovered protected v3.1 evidence archive is 662,434 bytes with SHA-256 `0ba1b7c22ad72cbf7b63d865aad92986a47005fff448fdb77ba3761eef2db48c` and 133 entries. The v3.0 public ZIP has 104 entries; the corrected v3.1 public ZIP has nine. Archive CRCs, SHA-256 declarations and the two Git-blob-only references were checked. Original native and protocol logs were opened, counted and matched to the appropriate source rather than relying on a report's claims. Inherited test times and known finite-test limits remain explicit.

No new Foundry or Go run was available in this runtime. Because contracts and node candidate source are unchanged and actual corresponding logs were retrieved, that limitation does not automatically reopen verified defects. It does limit claims about new local compilation, environment-specific race behavior and complete production rollout. The report claims none of those. Public verification scripts perform source/artifact integrity checks without executing private attacks or sending transactions.

10. Production observations and deployment limitations

Fresh read-only RPC verification found **57 of 57 recorded runtime Keccak hashes matching**, **57 of 57 successful receipts matching canonical numeric block hashes**, and **60 of 60 manifest receipt/address references consistent**. Approval-source comparison covers 43 distinct approval commits. The actual commands, timestamps, endpoint results and bounded summaries are archived. These checks establish observed deployment identity; they are not a new reproducible-build proof or two-provider agreement for every address.

Both rpc1.xgr.network and rpc2.xgr.network reported `xgrchain/v3.4.0/linux-amd64/go1.23.11`, had advanced beyond configured fork block **12,186,213**, and agreed on its canonical hash. The current observed XGR registry has three members and threshold two. The observed execution Gateway has distinct owner and service-wallet addresses. Supplementary Base/Arbitrum committee/role reads later returned HTTP 403. Earlier successful deployment code/receipt observations remain valid. The denied supplementary reads are retrieval limitations, not evidence of an unhealthy registry or a reason to invent NO-GO.

At **2026-10-29T08:55:03Z**, the public managed-service health GET returned HTTP 200, `paidQuoteReady=true`, and sponsorship enabled/available on Arbitrum, Base and XGRChain. No signed quote was requested. The observation supersedes the historical unavailable-service premise of F-15. It does not establish the complete effective database role, the exact installed worker revision, the paid-obligation inventory, grant outcome, automatic monitor operation or every original/current service boundary. The local supported-role failure in F-06 is independently demonstrated even when that readiness query is true.

Historical one-hop and two-hop transaction/stage evidence remains inherited. Source-stage commitments, exact receipt identities and current corresponding controls were rechecked, but no new productive one-hop or two-hop transfer, sponsor grant or wallet prompt was executed. Existing immutable evidence can support installation reconciliation without a new funded experiment. The audit does not claim fresh end-to-end production sponsorship or every-host delivery.

Per-host binary digests, effective private role inventory, current private debt/journal state and long-running monitor output are the principal outstanding installation evidence items. They are stated precisely rather than converted into vulnerabilities. If an installation-specific launch decision requires one, ask for an existing sanitized read-only record first. The source-level F-33 and F-06 counterexamples are already verifiable and do not rest on those gaps.

11. New findings and regression deduplication

There are three new unique findings. The fourth Phase A class reopens F-06 and is not assigned another ID. F-34's two transition cases are one state-model defect. F-35 concerns optional statistical observation and is distinct from node retry fairness (F-04), dense source indexing (F-25) and active-route delivery refresh (F-26). The new cases are scoped below with prerequisites, exact source references, bounded proof, impact, existing countermeasures, severity and minimum acceptance criteria.

F-33 - Timed-out sponsor recovery can initiate a late prepared payout

Medium / P1 / OPEN; confidence High. Phase A origin: A-02; sponsor A-SP-01.

Technical cause. Prepared-transaction recovery added a broadcast side effect inside a callback still raced as read-only. Promise.race times out its caller but never cancels the underlying callback. The destination-delivery gate precedes a potentially delayed nonce/transaction lookup; a late callback can initiate a send after the caller reported the work held and after independent destination completion.

Prerequisites. A valid paid commitment has a durable prepared transaction that is not yet known included. Destination is initially undelivered. A later RPC read outlives the reconciliation deadline but eventually resolves while the process remains alive; the original destination may have completed during that delay.

Failed or affected invariant. Brief invariant 4: no new gas payout after completed destination delivery. Also violates the internal promise that timed-out read work cannot start a payout.

Bounded verification. In an isolated actual-function test, a provider result was delayed beyond the configured test deadline. Reconciliation returned held with no broadcast. The destination then became complete, and resolving that delayed result caused the original prepared bytes to be submitted outside the returned operation. No network service, real account or production payment was used; executable reproduction and raw trace remain restricted.

Impact and limits. The worker can start a gas payout after it has returned a held outcome, using obsolete delivery eligibility. Operator hold/deadline semantics and the no-new-payout-after-completed-delivery rule are violated. Exposure is bounded by the original signed grant value and its transaction-fee limits; no arbitrary recipient/amount, duplicate transaction, bridge-principal loss or nonce reuse is demonstrated.

Existing controls. Only original stored bytes can be broadcast; recovered sender/recipient/value/nonce/chain are verified. Database grant-key and chain/sponsor/nonce uniqueness remain. An initial canonical delivery check exists; it lacks a valid effect-time deadline boundary.

Severity rationale. Medium because routine delayed I/O can violate an explicit financial-control boundary without a compromised signer, and reported holds no longer prevent new side effects. High is not justified: signed intent, bounded amount, nonce uniqueness and principal authorization are intact.

Minimal remediation. Keep raced inspectors strictly read-only: return an observation/action descriptor and let only the still-active caller decide whether to broadcast. After slow preflight reads, recheck canonical delivery and ownership; reject an expired or canceled generation immediately before broadcast, with no intervening await. Atomically invalidate that ownership on timeout/stop. A local per-grant generation/cancellation guard is sufficient where one caller owns the work; add a durable lease/fence only where actual overlapping workers require cross-process coordination. An expired inspector must never start a send. If broadcast already started, preserve uncertainty and reconcile the exact hash rather than pretending cancellation reverted a network effect. Do not sign a replacement, reuse the nonce, delete the promise or introduce another user signature.

Regression acceptance.

- A delayed preflight that resumes after timeout starts zero new broadcasts, even if every old read later succeeds.
- Completion observed by the final canonical delivery recheck prevents a new broadcast; timeout or expired ownership always prevents one. Completion after the last observation remains the stated read-to-send/inclusion race.
- An expired worker generation cannot act after a later sweep acquires ownership.
- Crash/restart still recovers only exact prepared bytes/hash; concurrent workers cannot submit different intent for the reserved nonce.
- An already-started broadcast with uncertain response retains its original liability/hash and is not declared canceled, settled or eligible for a different replacement.

Exact frozen source. `services/managed-relay/gas-sponsor.mjs:423-431`, `services/managed-relay/gas-sponsor.mjs:437-458`, `services/managed-relay/gas-sponsor.mjs:473-489`, `services/managed-relay/gas-sponsor.mjs:539-581`.

Evidence provenance. Newly reproduced during sealed Phase A; no further test execution during this integration step. The earlier missing-bytes F07 condition is separately resolved and is not re-counted here. The structured row supplies SHA-256 references for the restricted sealed harness, direct execution log and command metadata. Observed code defect; no production occurrence claimed. An off-chain guard cannot eliminate the ordering gap between its final canonical observation, initiating a send and later on-chain inclusion. That residual race is distinct from the demonstrated post-timeout send and is not claimed eliminated by this remediation.

F-34 - Provisional spendable state diverges from recovered or current receipt evidence

Low / P2 / OPEN; confidence High. Phase A origin: A-03; sponsor A-SP-02 including test subcase A-SP-03.

Technical cause. The new spendable_at marker lacks complete state transitions: crash-recovered canonical inclusion sets the marker while leaving the grant reserved with its tx_hash still NULL despite the durable prepared hash, whereas a later absent or noncanonical receipt leaves an old submitted grant marker intact. Public projection recognizes submitted+marker but cannot distinguish historical from current inclusion.

Prerequisites. Either a crash leaves a prepared reserved grant whose transaction becomes canonically included before safe confirmation, or an already observed provisional receipt later disappears or fails canonical verification.

Failed or affected invariant. Truthful separation of reserved, submitted, provisionally spendable and safe confirmed states. This is an additional state-projection property, not evidence that original principal or double-payment invariants fail.

Bounded verification. Sealed isolated tests exercised the actual reconciler with valid signed intent and canonical inclusion short of safe confirmation, observing marker-only recovery. A second isolated case removed receipt evidence from a previously spendable submitted grant and observed that only scheduling metadata changed. These two cases are one finding.

Impact and limits. The first case unnecessarily blocks normal UI progression despite usable gas; the second can advertise usable gas without current supporting inclusion evidence. User-visible readiness and grant status diverge from the actual lifecycle. No duplicate payment or incorrect permanent confirmed settlement is established.

Existing controls. verifiedSponsorFinality still controls confirmed settlement. The continuation preflight at transfer-actions.js:696-702 checks actual wallet native balance after simulation/gas estimation and refuses insufficient gas before a user signature. This limits stale readiness to availability, presentation and failed-attempt risk.

Severity rationale. Low because the defects alter provisional readiness rather than principal authority or durable final confirmation. Current wallet-balance preflight and exact-transaction journal prevent the demonstrated status error from becoming authority to overspend or issue tokens.

Minimal remediation. On verified crash-recovered inclusion, atomically persist the original prepared hash, promote reserved to submitted, and record provisional inclusion while keeping confirmed separate. Store enough inclusion identity to revoke/downgrade a disproved provisional marker when a canonical receipt changes or vanishes; distinguish an unknown transient RPC response from a verified reorganization. Preserve original signed intent, debt and nonce ownership.

Regression acceptance.

- A prepared reserved grant observed canonically included enters submitted with its exact prepared hash and is projected spendable before safe finality.
- A confirmed reorganization or changed canonical receipt removes current spendable readiness without deleting the owed grant or signing another payout.
- An unavailable RPC produces an explicitly uncertain projection rather than silently converting a past inclusion timestamp into current proof.
- Actual wallet balance preflight still rejects a continuation without sufficient current gas.
- Safe-finality confirmed logic and original transaction identity remain unchanged.

Exact frozen source. `services/managed-relay/gas-sponsor.mjs:491-501`, `services/managed-relay/gas-sponsor.mjs:541-550`, `services/managed-relay/gas-sponsor.mjs:577-581`, `services/managed-relay/server.mjs:330-350`, `services/indexer/sql/015_sponsor_spendable_receipt.sql:1-6`, `apps/web/transfer-actions.js:696-702`.

Evidence provenance. Both transition cases were newly reproduced during sealed Phase A. No additional execution occurred for this integration document. N08 permanent safe-confirmation checks were independently retained and remain resolved. The structured row supplies SHA-256 references for the restricted sealed harness, direct execution log and command metadata. Only local source behavior is demonstrated. Production UI symptoms and actual reorganizations were not induced or asserted.

F-35 - An out-of-scope record can indefinitely stall optional gas observation

Severity: Low. **Disposition:** OPEN. **Confidence:** High. **Priority:** P2. **Independent Phase A origin:** A-Q2. This is a new finding at `xgr-network/xgr-interchain@5cfc095d0f02271427832ee6bbb268322f38ae2d`; the related node reachability review uses `xgr-network/xgr-node@51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671`. The finding concerns the optional gas statistics service and does not demonstrate principal loss, unauthorized delivery, consensus failure or insufficient sponsor funding.

Condition and root cause.

The delivery collector scans every `ProcessId` event emitted by a configured shared Mailbox. To advance a range, it requires each qualifying event to match exactly one delivered transfer operation in its database, a route in its current generated catalog, and a usable gas profile. An absent operation or profile marks the entire range incomplete. The function then leaves its previously persisted cursor unchanged, causing the next tick to revisit the same range. It has no separate deferred-item mechanism or exclusion state for records that will remain outside this indexer's scope. See gas-observer.mjs, lines 94–143.

The onward collector exhibits the same dependency on the first unusable record. It reads child operations in cursor order, then breaks on the first unknown profile, ineligible receipt or caught failure. A child record whose route is no longer represented in the current catalog can remain permanently unprofileable and block later independent records. See gas-observer.mjs, lines 43–74.

The mechanism is withheld cursor progress, not a database rollback of previously accepted samples. Valid samples encountered earlier in a delivery window may already have been recorded; repeated visits are deduplicated by the measurement store but still repeat work. In the onward path, the cursor can advance through preceding valid rows and then remain before the obstructing row.

Input reachability.

The missing-row condition need not be a temporary indexing delay. The factory permits callers to deploy their own collateral or synthetic routers using the shared Mailbox and to register valid routes without enrollment in the web catalog. The protocol track independently confirmed that node route discovery consumes and validates registry routes separately from that catalog. The transfer index used by the learner, by contrast, enumerates only catalog-deployed routes. A normal valid delivery for a self-financed, uncatalogued route can therefore emit a shared-Mailbox event for which this indexer will never create the required operation row.

The relevant frozen-source boundaries are:

Boundary	Evidence
Caller-owned router deployment uses the shared Mailbox	XETATokenFactoryV315.sol, lines 136–168
Permissionless registration validates router ownership and route identity, without UI-catalog enrollment	XETATokenFactoryV315.sol, lines 189–229
Node discovers and attaches registry-proven routes independently	iln_discovery.go, lines 93–140
Transfer index enumerates generated-catalog routes	transfer-index.mjs, lines 36–48; route-availability.js, lines 65–73

This path requires a valid route and normal deployment, source-fee and destination-execution costs. It does not require a forged BLS authorization. No chain transaction or attack-cost measurement was performed for this audit, and the finding does not characterize the trigger as free or cheap.

Impact and severity.

One permanently unsuitable event can prevent later delivery-sample ranges from progressing for the affected chain/Mailbox. An unsuitable first onward record can stop the singleton onward scan across later records. Existing profiles can then become stale while the service continues repeated bounded reads.

The quote profile read retrieves sample count and percentile without enforcing age, and the quote calculation has no freshness-based fallback. This makes stale estimates a meaningful operational consequence, although no specific underfunded grant was demonstrated. See server.mjs, lines 206–216 and transfer-gas-profile.js, lines 43–54.

Low severity reflects the restricted impact on ancillary measurement availability. The collector does not authorize principal transfers, hold the sponsor signing key or release financial obligations. Independent quote capacity and grant limits remain applicable. This finding is distinct from F-04's node signing/retry observer, F-25's dense source-event indexing window, and F-26's delivery-refresh fairness defect.

Bounded verification evidence.

The auditor invoked the unchanged observer functions with the frozen deployment catalog and deterministic local RPC/database fixtures. Two successive delivery sweeps over the same canonical window containing an unindexed event left the established cursor unchanged. A separate onward fixture placed an unprofileable row ahead of a valid row; the collector performed no receipt reads or cursor writes for the later work. Additional negative controls rejected incorrect chain identity and canonical block-hash mismatch. A profile-age assertion documented the existing lack of freshness fallback.

The sealed Phase A execution passed **4/4 test cases** using Node v24.22.1 on 2026-10-29, from 08:51:46.086307 UTC to 08:51:46.261182 UTC. These passing assertions reproduce the defect and the preserved negative controls; they do not establish a remediation. Runtime fixture evidence proves the control flow, while the independent protocol/source comparison establishes the normal permissionless reachability described above. No production outage is asserted.

The protected evidence identifiers are `quote/observer-adversarial-detailed.log` and `quote/observer-adversarial-detailed.json`; their SHA-256 values appear in the companion public finding record. The custom negative executable is retained in the confidential evidence package and is not part of this public section.

Minimal remediation and closure check.

Separate the progress of the optional measurement scan from the eligibility of any one sample. Classify or quarantine permanently out-of-scope records with an explicit reason and counter, then advance across the canonical range so later independent samples remain reachable. Transiently missing indexed data can receive a bounded deferred retry; an explicitly documented sample-drop policy is also possible for statistics. Keep the canonical range boundary valid even when one optional sample is excluded.

Every accepted sample must retain the current chain-identity, successful-receipt, canonical-hash and native-finality checks. Contradictory chain evidence must not be recorded as a valid measurement. Statistical exclusion must never count as evidence that a sponsor promise can be released or settled. Add a conservative fallback for aged profiles so stalled learning does not silently preserve an old estimate indefinitely.

A sufficient focused regression should show that an out-of-scope item cannot prevent a later valid independent sample from being considered, while mismatched chain/hash evidence still cannot create a sample or justify an invalid cursor boundary. No contract deployment, extra user signature or protocol change is required.

F-06 regression rationale

The prior operations/resolutions grants remain correct. The recurrence is a newly added SELECT against quote intents and a new monitor read against overtaken obligations without corresponding canonical grants/readiness coverage. Both have the same role-contract root cause as F-06 and are counted once. A particular consolidated writer may already have suitable authorization; the audit does not assert a production failure on every installation. The supported canonical restricted-role path, however, is reproducibly broken and cannot be declared resolved from a green health response.

12. Residual risks, assumptions and acceptance

Principal security depends on valid source observations, validator quorum/signing keys, exact contract/route domains, chain-native finality and preserved replay/accounting rules. The audit did not demonstrate a new breach of that boundary. It does retain the explicit external-provider correlation risk and the registry-domain limitation. Resource admission, discovery completeness and recovery liveness depend on bounded workload and operational support; positive happy-path tests are not saturation proofs.

Sponsor financial commitments are a separate risk class. Exact-byte journaling and nonce uniqueness prevent the demonstrated crash recovery from changing intent, yet a late effect violates a promised control boundary. Conservative liability retention is safer than deletion but is not a complete paid-obligation outcome. Quote aliases and double counting affect service availability and must not be solved by releasing uncertain debt. Provisional UI readiness must not be confused with final accounting.

F-11's existing single-active-registry deployment acceptance is retained with its original scope and review triggers. The operator must revisit it before duplicate registries or equivalent signing domains can coexist in a way that changes the replay assumptions. No new acceptance for F-03/F-04/F-05/F-08/F-09/F-17/F-19/F-20/F-21/F-29/F-32/F-33 is made by the auditor. Conditions in a launch recommendation do not constitute operator acceptance.

F-15 and F-28 are Informational assurance items. Compiler/dependency identity is recorded, but no unverified current advisory applicability claim is made and no new semantic compiler proof is invented. Missing installation records remain specific follow-up questions. A new mainnet payment, additional user signature or unsafe production recovery is not required to answer them.

Historical severity remains immutable in the preserved reports and matrix. Resolved findings retain their old identity and cause while being excluded from current residual severity totals. The management categories have exactly two outcomes for Medium causes: SCHLIESSBAR or OFFEN. PARTIALLY_MITIGATED and ACCEPTED_RISK are not a hidden third closure category. No item is labelled RELEASED across all hosts without the corresponding evidence.

13. Separate release decisions and conditions

Audit **XITA-DBLS-2026-10-29-v3.2.0** assesses Interchain `5cfc095d0f02271427832ee6bbb268322f38ae2d` and node `51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671`. These decisions apply to the frozen source and the specifically observed deployment evidence. They do not certify installation on every host, authorize a production change, or accept new residual risks on behalf of the operator.

Operating scope	Decision	Basis and boundary
Core Direct-BLS / self-funded transfers	CONDITIONAL GO	Verified native fixes, unchanged authorization contracts and positive deployment observations support a restricted scope. External witness trust, native-claim presentation, managed quote availability and recovery conditions remain explicit.
Optional gas sponsorship / two-hop obligations	NO-GO for regular unattended operation	F-33 demonstrates a new post-timeout payout effect. F-06 breaks supported restricted-role admission/monitoring. F-08 and F-19 prevent an unconditional autonomous servicing claim. This is a source decision, not an assertion of observed production exploitation.
Recovery / operational availability	CONDITIONAL GO	Supervised validated core proof/delivery recovery and read-only sponsor journal/evidence inspection, with active backlog monitoring and documented finite recovery limits. The unsafe automated sponsor replay path is excluded until its effect boundary is corrected or a separately assessed workflow demonstrably avoids it.

Core Direct-BLS / self-funded transfers: CONDITIONAL GO.

No new principal-authorization, message-forgery, replay or native-accounting regression was demonstrated in the complete delta and inspected dependencies. The prior native accounting fixes remain verified against the exact retained candidate source and actual execution logs. Both observed XGR RPC endpoints identify v3.4.0 and agree on the configured fork block. Recorded runtime hashes and canonical receipts match all 57 checked deployments. Those positive results support the decision; the absence of an individual host attestation does not reverse it by itself.

The restricted scope requires the documented active registry/quorum and v3.4 accounting-fork configuration, authenticated route/Gateway/ISM bindings, and chain-native finality. External Base/Arbitrum source evidence still relies on distinct operator-labelled witnesses with possible correlated upstreams (F-05); the operator must retain the documented trust model and explicitly address any expansion beyond it. The existing single-active-registry risk acceptance for F-11 remains bounded to its stated deployment model.

Native delivery must distinguish a completed Mailbox message from a recipient's deferred native claim (F-09). Preserve the previous restricted native-recipient scope: ordinary code-free recipients, or a separately verified supported wallet with a usable beneficiary claim path. Arbitrary recipient contracts are not approved merely because the claim is backed; some have no way to call it. Until the UI is corrected, the restricted service must expose and operationally handle pending claims rather than representing every processed message as fully received principal. Recovery support must retain source transactions and message identities, monitor backlog/cursors, and use independently validated known-hash recovery when automatic discovery is incomplete. F-03/F-04/F-20/F-21/F-29/F-32 preclude an unqualified scalability or availability guarantee, but their stated prerequisites do not independently demonstrate principal compromise or require a blanket core NO-GO.

Self-funded does not imply independence from the managed quote API. The new intents SELECT runs for wallet-aware pricing even when grants are zero. A fully funded wallet can therefore encounter F-06. Core safety approval is conditional on an unaffected quote path or demonstrated correct privileges for the

actual managed role; user gas alone is not an availability bypass. Missing installation evidence should prompt a targeted request for existing sanitized source/role records if a concrete release decision depends on it.

No additional risk acceptance is recorded by this audit. If the operator cannot satisfy a stated condition, that operating scope requires a separate decision; the report does not silently treat an unverified condition as accepted.

Optional gas sponsorship: NO-GO for regular unattended operation.

F-33 is a demonstrated financial-control defect in the newly implemented recovery path. A timed-out callback can later start broadcasting the original authorized grant after the operation returned held and delivery completed. Watching the same unsafe callback does not eliminate its effect. The grant remains bounded and nonce/intent protections remain; no duplicate payout or principal loss is asserted. The defect nevertheless contradicts the requested no-new-payout-after-delivery invariant and prevents approval of regular operation on that path.

F-06 requires the narrow missing SELECT grants/readiness checks in the supported role model, or evidence that a particular installation already has those authorized privileges. Public paidQuoteReady=true does not prove this because the readiness query omits the dependency. F-08 still needs bounded read preflight and fair independent servicing for an autonomous outage-resilience claim. F-19 preserves paid obligations but lacks a complete controlled outcome process and separates neither stop-new-admission nor drain-existing-debt cleanly.

F-19 alone does not prohibit every staffed, controlled service. Such a service would need an explicitly approved and workable settlement policy with ownership, escalation and traceable outcomes. An append-only ledger or indefinite hold alone is not fulfillment. This policy cannot compensate for F-33. F-17 is a bounded unpaid-admission availability risk and is not an automatic NO-GO; an operator must explicitly approve the intended service limits rather than the auditor assuming acceptance.

The minimal route to reassessment is to correct and negatively test the effect boundary, verify effective restricted roles, establish safe obligation servicing/outcomes, and bound remaining read-only provider waits. No new user signature, new production test transfer, automatic late payout, nonce reassignment, or debt deletion is required or recommended. No production switch or worker restart is instructed: the current global stop also suppresses old-debt servicing and must be considered in any separately authorized operating plan.

Recovery / operational availability: CONDITIONAL GO.

Known source hashes, exact message identities and independently verified canonical proofs support supervised core recovery. F-26's exact-pair SQL fairness correction is freshly verified. Native signing synchronization guards and existing durable-retry controls remain in place. Current limits are retry fairness, missing-route deletion, successful-incomplete scans, dense index windows, stale admin locks and UI recovery presentation. Monitor oldest work and retained evidence, and use bounded, explicit recovery rather than claiming every background cursor is complete.

This scope includes read-only sponsor journal/evidence inspection and controlled investigation of uncertain or pre-upgrade rows. It excludes the defective automatic sponsor rebroadcast under F-33; the function named reconcileSponsorGrants itself can write and broadcast and is not a read-only inspection command. Preserve original nonce ownership, exact signed transaction hash and all liabilities while status is uncertain. Human supervision is not an exemption for the demonstrated asynchronous late effect.

Evidence gaps and targeted follow-up.

The observed public health response and 57 deployment checks are affirmative but scoped. Remaining host/role/journal/monitoring attestations are assurance tasks under F-15, not fabricated production faults. If installation approval depends on them, request the effective read-only role privileges, exact installed revision, aggregate unresolved-debt/age summary and existing monitor output before making an adverse installation conclusion. The source blockers above already have independent local counterexamples, so their existence does not depend on that missing evidence.

14. Remediation matrix and implementation order

Only audit documents are changed by this publication. All product corrections below are recommendations for a separately authorized implementation. Prefer small changes which directly remove the proven cause, and preserve the original signing, finality, debt and nonce boundaries.

First implementation sequence.

1. **F-33: make timeout/ownership valid at the broadcast boundary.** Move effects out of raced read callbacks, invalidate an active generation on timeout/stop, revalidate delivery/ownership after slow reads, and check that generation immediately before broadcast without another await. Add durable fencing where ownership spans competing or restarted workers. Preserve a send already started as uncertain; cancellation is not rollback. Require zero late broadcasts after a timeout or observed completion, plus exact-byte restart and concurrent-worker negatives. This is the first financial-control priority.
2. **F-06: repair exact role/readiness dependencies.** Add SELECT on quote intents for the documented signer and on overtaken obligations for the status reader. Exercise the full quote and monitor under the real restricted roles, including failure rollback and readiness. Do not grant UPDATE/DELETE on immutable debt records or use superuser as the fix. The change is small and should be tested independently from F-33.
3. **F-34 and F-30/F-16 regression retention.** Persist the prepared hash and submitted transition atomically on recovered inclusion; separate historical observation from current provisional readiness; downgrade a disproven canonical inclusion without deleting debt. Keep safe confirmation separate. Retain the newly verified immutable-age and two-witness release tests.
4. **F-19/F-08: complete controlled paid-obligation handling and bound read work.** Separate new admission from old-debt reconciliation, define an auditable operator-approved outcome for overtaken debt, and give healthy chains fair service under provider failure. Timeouts must cover read-only preflight without enclosing uncancellable payout side effects. Do not introduce automatic post-completion gifts or release uncertain obligations for capacity.
5. **F-09/F-31/F-35/F-14: fix precise presentation, observer and coverage gaps.** Present deferred native claims, prioritize explicit destination failure, let optional statistical samples make bounded independent progress while retaining accepted-sample verification, and include new tests in CI. Keep main transfer/debt cursors separate from optional sampling policy.
6. **Node availability residuals F-03/F-04/F-20/F-21/F-29/F-32.** Add bounded admission, fair scheduling and durable consume-after-success semantics in separately reviewed small changes. Test outage and saturation locally before expanding supported load. Do not disable source verification or weaken finality to obtain progress.

Priorities distinguish effect/financial boundaries from availability and evidence maintenance. No current Critical or High remediation is claimed. F-11 remains the existing documented acceptance; all other proposed residual acceptances require an explicit operator decision.

Complete current-finding remediation matrix.

ID / priority	Current disposition	Smallest appropriate action
F-01 / Maintain	VERIFIED / RESOLVED	Maintain the established fork configuration and release identity controls. Retain the rejection/accounting regressions and continue ordinary rollout/configuration reconciliation. No new corrective product change is required for the original condition.
F-02 / Maintain	VERIFIED / RESOLVED	Preserve fork-gated transaction-local accounting and the retained differential/rejection regressions. No further fix is needed for the demonstrated original cause.
F-03 / P1	OPEN	Add cheap bounded admission and in-flight deduplication before remote reads, followed by bounded global/per-peer concurrency and fair service. Bound governance proposal count, storage and future lease. Keep complete source verification before signing and validate consensus continuity under controlled load.
F-04 / P1	OPEN	Persist or otherwise maintain a fair rotating route cursor, preserve original evidence when quarantining corruption, and expose backlog age/capacity. Test that a late healthy route progresses through sustained earlier failures and that capacity pressure remains isolated.
F-05 / P1	OPEN	Document and verify actual primary/fallback upstream independence, monitor disagreements, and keep fail-closed complete evidence checks. Treat a newly discovered common controlling upstream as a reason to reassess the configured witness set, without redesigning Direct-BLS solely because the dependency exists.
F-06 / P1	OPEN	Grant only SELECT intents to actual permitted writer and SELECT overtaken table to status reader; require exact restricted-role readiness/CI checks.
F-07 / Maintain	VERIFIED / RESOLVED	Do not remove nonce uniqueness or re-sign an uncertain legacy payment. Preserve pre-upgrade obligations, reconcile their exact transaction identity under operator control. Address A-SP-01 separately with effect-safe deadlines.
F-08 / P1	PARTIALLY_MITIGATED	Use bounded read-only preflight and per-chain fair scheduling for fresh candidates; keep payout effects outside uncancellable race callbacks and keep sweep work inside its service time budget. Add a controlled-promise candidate test proving healthy independent-chain progress.
F-09 / P1	OPEN	Before initiation enforce the stated supported native-recipient policy where required, and distinguish confirmed Mailbox delivery from deferred principal. Surface existing beneficiary-authorized recovery accurately for supported wallets. Do not invent an additional mandatory user signature or sponsorship transaction; the existing withdrawal is an exceptional claim path.
F-10 / P2	OPEN	Keep independent key custody and check both current and pending ownership before role rotations. In a future contract revision enforce inequality at nomination, acceptance and setServiceWallet, covering either transition order.
F-11 / P1	ACCEPTED_RISK	Maintain the documented single-active-registry invariant and explicit receipt-pinned configuration. Reopen domain design before overlapping equivalent migrations; use a deliberately versioned address-bound membership scheme if that invariant changes.
F-12 / P1	OPEN	Monitor the assessed minimum of three independently operated active keys and current-set re-attestation continuity. Introduce an on-chain minimum only as an explicit governance/migration decision; current operating controls remain proportionate to this Low risk.
F-13 / P2	OPEN	Decode process arguments and validate the actual Direct-BLS message/authorization identity before eth_sendTransaction; add adversarial substituted-valid-message test.

ID / priority	Current disposition	Smallest appropriate action
F-14 / P2	OPEN	Correct only expectations contradicted by intentional documented behavior; add new test files to CI discovery; ensure expiry mock reaches WITH due AS; preserve negative assertions for forbidden writes.
F-15 / P2	OPEN	Request existing sanitized service revision/migration/role checks, aggregate aged journal status and already-existing representative paid one-/two-hop evidence when deciding installed readiness. Do not require a new Mainnet payment or lower core release status solely because an individual host attestation is absent.
F-16 / Maintain	VERIFIED / RESOLVED	Maintain independent RPC operators and monitor retained-resolution backlog. Preserve fail-closed behavior and add a functioning caller-level outage regression for the obsolete N-06 query stub. No further code correction is required to eliminate the original single-view/no-reread condition.
F-17 / P1	PARTIALLY_MITIGATED	Measured fair and bounded provisional admission; retain all uncertain/paid liabilities and explicit retry visibility. No extra user signature mandated.
F-18 / P2	OPEN	Define mutually exclusive confirmed-spend and unsettled-obligation sets, keeping every uncertain grant represented exactly once. Add real-schema tests for reserved/submitted/confirmed/needs-review and rolling-window boundaries before changing financial arithmetic.
F-19 / P1	PARTIALLY_MITIGATED	Keep obligations, original transaction identities and nonce reservations intact. Separate stopping new quote admissions from read/reconciliation of existing grants; document and implement a narrowly authorized outcome record for externally completed promises. Use operator review, not automatic post-delivery gas transfers or deletion. Fix read-only monitor privilege coverage through F06.
F-20 / P1	OPEN	Retain the original locator/evidence until a successor is durably persisted or delivery is authenticated as terminal. Use an atomic handoff for rotation and cleanup, then test failure after discovery, after rotation, during successor persistence and across restart.
F-21 / P1	OPEN	Add bounded overlap/reconciliation or independent-provider completeness checking to discovery. Preserve known-transaction recovery and alert on differing windows. Keep full two-witness source verification for every eventually discovered message.
F-22 / P2	OPEN	Reuse shared chain-native finality policy and compare receipt height/hash before promotion; label provisional confirmation depth separately.
F-23 / P2	OPEN	Provide minimal explicit stale-owner verification/recovery retaining journal, nonce and signed-byte identity; never delete a lock solely because its wall-clock age is large.
F-24 / P2	OPEN	Pass verified row.message_id and row.source_tx_hash into the event; add successful-store regression.
F-25 / P2	OPEN	Adaptively split bounded block ranges, preserving complete canonical event processing; define a bounded dense-single-block path and retain cursor on uncertainty.
F-26 / Maintain	VERIFIED / RESOLVED	Retain exact-pair selection before LIMIT and outage scheduling regression. No product correction is needed for the original cause.
F-27 / Maintain	VERIFIED / RESOLVED	Retain nonempty CLI field checks and embedded revision/checksum checks in release validation. Reconcile deployed host binary identities through ordinary operations when available; the original linker-path defect is closed.

ID / priority	Current disposition	Smallest appropriate action
F-28 / P2	OPEN	First verify the exact official advisory and trigger applicability if this task is pursued as a concrete exposure. Then qualify the precise build/settings with a targeted corrected compiler or suitable equivalence method. Do not infer a need to redeploy existing contracts solely from the historical unexcluded question.
F-29 / P1	OPEN	Carry bounded context-aware transport through preflight, submission and receipt waits, and test complete Worker.Close termination. Preserve original transaction identity and nonce when a send outcome is uncertain; an outer sleep timeout or blind replacement broadcast is insufficient.
F-30 / Maintain	VERIFIED / RESOLVED	Retain immutable age predicates, restore the reader privilege dependency under F06 and verify installed alert delivery with existing synthetic/aggregate evidence. Do not conflate heartbeat age with debt age.
F-31 / P2	OPEN	Record and prioritize explicit destination-receipt failure state over stale pending stage; keep the existing source evidence and only offer destination retry.
F-32 / P1	OPEN	Apply a global bounded admission/retention policy to unverified request storage and reap expired unknown-route directories, or allocate message jobs only after canonical route admission. Preserve verified votes and paid recovery obligations; test hint rejection, expiry, churn and restart cleanup.
F-33 / P1	OPEN	Keep raced inspectors strictly read-only: return an observation/action descriptor and let only the still-active caller decide whether to broadcast. After slow preflight reads, recheck canonical delivery and ownership; reject an expired or canceled generation immediately before broadcast, with no intervening await. Atomically invalidate that ownership on timeout/stop. A local per-grant generation/cancellation guard is sufficient where one caller owns the work; add a durable lease/fence only where actual overlapping workers require cross-process coordination. An expired inspector must never start a send. If broadcast already started, preserve uncertainty and reconcile the exact hash rather than pretending cancellation reverted a network effect. Do not sign a replacement, reuse the nonce, delete the promise or introduce another user signature.
F-34 / P2	OPEN	On verified crash-recovered inclusion, atomically persist the original prepared hash, promote reserved to submitted, and record provisional inclusion while keeping confirmed separate. Store enough inclusion identity to revoke/downgrade a disproved provisional marker when a canonical receipt changes or vanishes; distinguish an unknown transient RPC response from a verified reorganization. Preserve original signed intent, debt and nonce ownership.
F-35 / P2	OPEN	Isolate individual optional statistical samples: classify/defer or exclude permanently out-of-scope records with a reason and counter, advance the main cursor over a canonical range, and allow later independent samples to progress. For transiently missing data, use a bounded retry/deferred record or a documented sample-drop policy. Preserve chain identity, successful receipt, canonical hash and native-finality verification for every accepted sample. Do not use statistical exclusions to settle or release sponsor obligations. Add an age-aware conservative profile fallback and a regression covering out-of-scope obstruction plus later progress.

15. Final statistics, artifact integrity and conclusion

Current residual severity	Unique findings
Critical	0
High	0
Medium	14
Low	12
Informational	2
Resolved original causes	7
Total register entries	35

Technical disposition	Unique entries
VERIFIED / RESOLVED	7
OPEN	24
PARTIALLY_MITIGATED	3
ACCEPTED_RISK	1

All 32 preceding current findings and all 43 historical occurrences have an explicit current disposition. Three new findings are added; F-06 is the sole reopened regression. Seven current-register causes are resolved: F-01, F-02, F-07, F-16, F-26, F-27 and F-30. The newly closed current causes are F-07, F-16 and F-30; M-03 is the additional legacy-only closure. No current Critical or High is asserted. No unresolved Medium is silently accepted or counted as resolved.

The deliverable follows the existing versioned `audits/` structure. It contains this complete English Markdown report and generated PDF, scope and change inventory, current and historical registers, immutable original Phase A commitment plus the identified public derivative, verification/test/remediation/launch documents, actual public evidence ZIP, confidential evidence reference and exact artifact manifest. Earlier audit directories are unchanged; the audit index points to this version while preserving older decisions as historical.

`archive-manifest.json` records the exact hashes and byte counts of the completed artifacts, with self-reference excluded. `evidence/MANIFEST.json` identifies every public evidence member, and `verify_artifacts.py` checks file identities, ZIP CRCs/member hashes, required files, unique current/historical IDs, severity/disposition arithmetic and Phase A publication commitments. `pdf-validation.json` records actual rendered page count, extracted-text completeness, artifact hashes and visual inspection. The complete private master, custom negative fixtures and raw sensitive traces are separately retained with a hash-bound access reference. A public reference is not a claim of unauthenticated access to that package.

The audit branch contains actual committed artifacts and is reviewed through a documentation-only pull request. Publication is completed only after successful required CI, merge and a fresh byte-for-byte readback from main. The publication commit is separate from the frozen product revisions. Final

merge/readback identifiers belong in the publication attestation and cannot be embedded self-referentially into the bytes whose hash they attest. The final communication records those actual outcomes rather than guessing them here.

The source-based conclusion is restricted CONDITIONAL GO for self-funded core transfers and supervised core recovery under the stated controls, with regular unattended sponsorship withheld because concrete technical blockers remain. Missing host attestation does not determine that sponsorship result. The narrow fixes described here preserve existing user signatures, principal rules, exact transaction identity and outstanding financial obligations.